

SyPrFL: Sybil-Resilient Privacy-Preserving Federated Learning via Differentially-Private Projection Clustering

Md Mazharul Islam^{a,*}, Mohammad Kaosain Akbar^b and Niaz Ashraf Khan^c

^aDepartment of Electrical and Computer Engineering, North South University, Dhaka, Bangladesh

^bDepartment of Computer Science, University of Calgary, Calgary, Alberta, Canada

^cDepartment of Computer Science and Engineering, BRAC University, Dhaka, Bangladesh

ARTICLE INFO

Keywords:

Federated Learning
Sybil Attacks
Differential Privacy
Secure Aggregation
Byzantine Resilience
IoT Intrusion Detection

ABSTRACT

Federated learning trains a shared model without pooling raw data, and is widely adopted for privacy-sensitive tasks such as IoT intrusion detection. In adversarial deployments it faces a structural impasse. Byzantine-robust aggregation needs plaintext gradients to compute the relational statistics it relies on, which reinstates the gradient-inversion attack surface. Privacy-preserving aggregation hides individual updates, and thereby removes the very signal needed to identify malicious contributions. Coordinated Sybil attackers exploit this gap. We first show that the gap is structural rather than incidental: any protocol in which the server derives a pairwise-similarity statistic from the same representation it aggregates must either leak individual updates or lose the coordination signal entirely. We then propose SyPrFL, a two-channel scheme that circumvents this obstruction. Each client submits a mask-based secure-aggregation share of its full update, together with a low-dimensional, differentially-private random projection of that same update. The server clusters the projections with HDBSCAN and scores cluster cohesion through a new Differentially-Private Projection Cluster Cohesion (DP-PCC) primitive. A weighted secure-aggregation construction then binds the resulting trust weights to the masked channel, keeping detection-side and aggregation-side information cryptographically disjoint. We establish formal guarantees on privacy, detection error, robustness, and convergence. Across three public IoT-IDS datasets (N-BaIoT, TON-IoT, Bot-IoT), ten baselines, and six attack instantiations, SyPrFL attains 97.64% clean accuracy on N-BaIoT, the highest of any evaluated defense carrying a formal privacy guarantee. Averaged over the five non-backdoor attacks it retains 95.9% accuracy on N-BaIoT, against 73.0% for FoolsGold, the strongest competitor that lacks a privacy guarantee. It reduces backdoor attack success from near 100% to 6.2%, at 1.18× the per-round latency and 1.03× the communication of plain FedAvg.

1. Introduction

Federated Learning (FL) trains a shared model across distributed clients without centralizing their data, and has emerged as the leading paradigm for privacy-sensitive applications including mobile inference, healthcare analytics, and the security monitoring of the Internet of Things (IoT) [1]. Among these, FL-based Intrusion Detection Systems (IDS) for IoT environments are particularly compelling [2]: IoT networks combine high-volume telemetry, strict regulatory constraints on raw data sharing, and an attack surface dominated by rapidly evolving botnets, none of which can be addressed by centralized batch training within current legal regimes.

This federated setting introduces two adversarial surfaces absent from centralized learning. Shared model updates leak information about the underlying training data, with gradient-inversion techniques able to reconstruct substantial portions of a client's training batch from a single update [3]. At the same time, clients lie outside the server's administrative control, so one or more compromised participants may submit arbitrarily crafted updates to degrade utility, induce targeted misclassifications, or implant backdoors [4]. Privacy threats and Byzantine threats are typically

treated as independent problems with independent solutions: secure or differentially-private aggregation prevents the server from inspecting individual updates [5], while robust aggregation rules discard or down-weight updates that appear as statistical outliers [6].

A third adversarial pattern sits between these two and is the focus of this work. Under a Sybil attack, a single physical adversary registers multiple distinct client identities and orchestrates their updates collectively, presenting the server with a coordinated minority masquerading as a majority [7]. Sybils are especially damaging in IoT-FL because they break the very assumption robust aggregators rely on: colluding clones, by every standard distance metric, present lower pairwise distance and higher mutual similarity than the genuinely heterogeneous honest clients, and are therefore mistaken by Byzantine defenses for a consensus majority. Weak IoT-gateway authentication makes such identities cheap to manufacture, so the threat is operational rather than theoretical.

The defining difficulty is that the natural detection signal for Sybil collusion is the relational similarity between clients' updates, and computing this signal requires the server to inspect individual updates in plaintext [8]. Privacy-preserving aggregation is designed precisely to deny the server that view. The two requirements pull in opposite

*Corresponding author.

 mazharul.islam1@northsouth.edu (M.M. Islam);

mohammadkaosain.akba@ucalgary.ca (M.K. Akbar); niaz.ashraf@bracu.ac.bd (N.A. Khan)

directions: any scheme that hides individual updates eliminates the Sybil-detection signal, and any scheme that exposes the signal eliminates privacy. A naive composition - for example, computing similarity on encrypted updates - either incurs prohibitive cryptographic overhead or leaks information through side channels of the similarity computation. The result is a deployment-relevant impasse. To our knowledge, no existing federated aggregation protocol, to our knowledge, simultaneously hides individual updates and resists coordinated Sybil collusion under realistic non-IID conditions [9]. Section 6.1 makes this claim precise. It gives a structural argument for why the two requirements conflict in any single-channel design, and it audits the closest prior art against the two properties individually.

This paper proposes SyPrFL, a Sybil-resilient privacy-preserving federated learning framework that closes the gap without resorting to general-purpose secure multi-party computation or zero-knowledge proofs. The core observation is that Sybil detection does not require the full client update; it requires only enough information about the relational structure of updates across clients to identify groups whose mutual similarity is statistically anomalous. Each client therefore transmits two complementary messages in each round: a low-dimensional random projection of its update perturbed with calibrated Gaussian noise, and the full update protected by mask-based secure aggregation. The server inspects the noisy projections freely but cannot inspect any individual full update.

Detection proceeds on the projection channel via the Differentially-Private Projection Cluster Cohesion (DP-PCC) primitive introduced in this paper. The server clusters the noisy projections, computes a cohesion statistic for each cluster equal to the mean pairwise distance, and compares it against an adaptive baseline that tracks the natural non-IID heterogeneity of recent rounds. Clusters whose cohesion falls below a configurable fraction of the baseline are flagged as suspected Sybil groups, and their members receive a reduced trust weight [10]. Aggregation then proceeds through a trust-weighted extension of mask-based secure aggregation, in which the server applies the trust weights to the protected client shares before unmasking. The server learns only the trust-weighted aggregate, never an individual update. Privacy follows from the secure-aggregation sub-protocol and the differentially-private projection; Sybil resilience follows from the statistical separation between coordinated and honest clients in projection space; and utility is preserved because the calibration of the differential-privacy noise to the projection dimension leaves honest clients untouched under normal operation. The contributions of this paper are as follows.

1. This work identifies and formalizes the Sybil blind spot in privacy-preserving FL, and shows that it is structural rather than an artefact of existing designs. Proposition 1 makes the difficulty precise: in any single-channel protocol, a server view fine enough to resolve the pairwise-similarity statistic that Sybil detection requires is also fine enough to reconstruct

the honest client configuration up to a rigid motion, so no such protocol can expose the detection signal and hide individual updates at the same time. This is why prior defenses cannot close the gap without abandoning either privacy or robustness.

2. SyPrFL is proposed, a two-channel aggregation protocol in which every client submits two derivatives of one clipped local update: a k -dimensional random projection released under the Gaussian mechanism, which the server inspects for detection, and the full update under mask-based secure aggregation, which it never inspects. Deriving both from the same update prevents a client from pairing a benign projection with a malicious masked contribution.
3. A new statistical primitive, Differentially-Private Projection Cluster Cohesion (DP-PCC), is introduced to detect coordinated client collusion through the cohesion of differentially-private projections against an adaptive non-IID baseline, with bounded false-positive and false-negative rates as a function of projection dimension, noise scale, and client heterogeneity.
4. A comprehensive IoT-IDS evaluation suite is constructed, spanning three public datasets (N-BaIoT, TON-IoT, Bot-IoT), six attack instantiations, and ten baseline defenses including FoolsGold, FLTrust, Krum, Multi-Krum, Median, Trimmed Mean, FedAvg, DP-FedAvg, SecAgg, and the closest published IoT-IDS baseline PEIoT-DS, together with a dedicated FoolsGold+DP comparison isolating the naive alternative to the two-channel design.
5. Empirical results across all three datasets and the full attack suite show that SyPrFL retains near-clean classification accuracy in regimes where privacy-only baselines collapse and robustness-only baselines lack the privacy guarantee required for deployment.

The remainder of this paper is organized as follows. Section 2 surveys related work across Byzantine-robust aggregation, privacy-preserving aggregation, and federated IoT intrusion detection, positioning SyPrFL against the closest competitors. Section 3 fixes notation and reviews the cryptographic and differential-privacy primitives on which SyPrFL relies. Section 4 formalizes the cross-silo system model and Section 5 the threat model, including the concrete attack instantiations used in the evaluation. Section 6 presents the SyPrFL protocol and the DP-PCC detection primitive, and Section 7 establishes its privacy, detection, robustness, and convergence guarantees. Section 8 describes the experimental setup, Section 9 reports and discusses the results, and Section 10 concludes with a summary of contributions and directions for future work.

2. Related Work

The literature relevant to SyPrFL spans three loosely connected currents: Byzantine-robust aggregation that hardens federated and decentralized training against malicious

participants, privacy-preserving aggregation that conceals individual updates from the server, and federated intrusion-detection systems that adapt both lines of defense to the constraints of IoT deployments. A growing number of works attempt to combine robustness and privacy, and a smaller set confronts coordinated clients masquerading as a benign majority. We review the most pertinent contributions across these currents and isolate the gap that SyPrFL is designed to fill.

The first current concerns robust aggregation in decentralized and federated optimization. Li et al. [11] filter neighbours whose accumulated loss exceeds an agent's own, achieving resilience at linear cost but with convergence established mainly for convex models. Li et al. [12] generalize the geometric median through a centerpoint aggregation rule that proves an $\mathcal{O}(1/i)$ rate, yet centerpoint computation becomes co-NP-complete for $d \geq 4$, forcing approximation in realistic parameter spaces. Confronting non-IID heterogeneity directly, Wu et al. [13] show that centralized rules such as Krum and the geometric median frequently fail to reach consensus in decentralized non-IID regimes and propose an iterative outlier-filtering aggregator, while Xu et al. [14] assign per-layer filtering radii to account for differing learning speeds across network layers. The recurring limitation is structural rather than incidental: every estimator requires the server to inspect individual updates in plaintext, which is precisely the capability privacy mechanisms remove, and none evaluates against attackers that coordinate to imitate the honest majority.

The privacy current attacks the problem from the opposite direction, concealing individual contributions, and in doing so hides the very signal robust aggregation depends on. So et al. [15] present the first single-server Byzantine-resilient secure-aggregation framework (BREA) but assume i.i.d. data for its convergence guarantee. Xia et al. [16] advance this to full information-theoretic privacy that leaks no pairwise distances, though communication and computation grow as high-degree polynomials in the number of users. Zhao et al. [17] take a hardware route using trusted execution to reconcile masking with the visibility robust aggregation needs, but are bounded by limited enclave memory and exclude side channels, while Aziz [18] proposes a zk-SNARK-based protocol that proves correct application of differential privacy at the cost of proving times that escalate with model dimension. These schemes deliver rigorous privacy but either forfeit robustness or impose overheads incompatible with real-time deployment, and none addresses Sybil-style collusion.

A hybrid current attempts to deliver privacy and robustness together while remaining lightweight, usually by adding differential privacy to a trust-based aggregator, and a closely related application current grounds these mechanisms in IoT intrusion detection. He et al. [19] couple adaptive local differential privacy with secure multi-party computation and anomaly detection for financial federations, while Guo et al. [20] pursue model compression and Byzantine robustness jointly through device-to-device validation, and Chaurasia

et al. [21] fuse reputation scoring with energy-adaptive participation for industrial IoT, requiring two-thirds honest participation per cluster. In the IDS setting, Khraisat et al. [22] improve convergence on the N-BaIoT botnet dataset but provide no defense against malicious participants; Al Amro et al. [23] combine differential privacy, secure multi-party computation, and a weight-distance detector that can be evaded by stealthy backdoors; and Sultana et al. [24] combine homomorphic encryption, differential privacy, and a trimmed-mean aggregator for medical IoT at non-negligible overhead. These hybrids represent real progress, yet they continue to treat malicious clients as statistical outliers relative to a benign majority, an assumption that coordinated Sybils violate by construction, and they do not evaluate Sybil-specific attack vectors.

Two observations crystallize the gap, corroborated by recent surveys [25, 26]. First, the works that provide strong robustness do so by inspecting plaintext updates, while the works that provide strong privacy do so by removing exactly the relational signal robustness requires; the hybrids that bridge the two still presuppose that adversaries are isolated outliers. Second, none treats Sybil collusion as a first-class threat: colluding identities present lower mutual distance than genuinely heterogeneous honest clients and are therefore mistaken for a trustworthy consensus, yet no surveyed protocol simultaneously hides individual updates and detects this coordination pattern under realistic non-IID IoT-IDS conditions. SyPrFL is designed for this empty intersection, decoupling the Sybil-detection signal onto a low-dimensional differentially-private projection channel while protecting full updates under secure aggregation.

Table 1 situates SyPrFL against the eight prior works most closely aligned with its goals, selected so that none duplicates the papers discussed above. The works are compared along six dimensions: the privacy mechanism employed, the Byzantine or robustness defense, explicit Sybil resilience, the application domain, the principal evaluation dataset, and the methodological category. The table reinforces the conclusion drawn from the prose: combining a privacy mechanism with a robustness defense is common, but explicit Sybil resilience is at best partial and incidental, and is never co-located with cryptographic privacy of individual updates under non-IID IoT-IDS workloads. SyPrFL occupies the otherwise empty cell at the intersection of differential privacy, secure aggregation, and provable Sybil detection in the IoT intrusion-detection setting.

3. Preliminaries

This section fixes the notation, states the federated learning setup, and reviews the cryptographic and statistical building blocks that SyPrFL relies on: mask-based secure aggregation and the Gaussian mechanism for differential privacy, together with the random projection, HDBSCAN clustering, and cluster-cohesion test that compose into its Sybil-detection pipeline.

Table 1

Comparison of SyPrFL against the eight most closely aligned prior works, disjoint from those discussed in the prose.

Work	Privacy	Byz.	Sybil	Application	Dataset	Approach
Prajwalasimha et al. [27]	✓(DP)	✓	?	6G IDS	6G network data	Byz. agg. + DP
Shaikh et al. [28]	✓(DP+SMPC)	?	?	Critical infra.	Simulated (50 nodes)	DL + SecAgg + DP
Camalan et al. [29]	✓(PIR+DP)	–	?	Cyber threat intel.	AbuseIPDB, URLhaus	PIR + FL + DP
Haq et al. [30]	✓(DP)	✓	?	Smart grid	IEEE 33-bus, SCADA	Decentralized FL
Li et al. [31]	∂ (rep.)	✓	∂	Vehicular nets	CIFAR-10 (200 veh.)	Digital twin + BC
Ramalingam et al. [32]	✓(HE+DP)	✓	?	Smart-env. IoT	Energy mgmt. sim.	GenAI + BC + FL
Khaf et al. [33]	∂	✓	∂	6G NTN spectrum	Simulated NTN	Hier. RL + trust
Isong et al. [34]	✓(HE)	✓	∂	Genomic analytics	1000 Genomes	Explainable Sec-FL
SyPrFL (this work)	✓ (DP+SecAgg)	✓	✓	IoT-IDS botnet	N-BaloT, TON-IoT, Bot-IoT	DP-proj. + clust. + SecAgg

Note. ✓ = provided; ∂ = partial or conditional; – = not provided; ? = neither claimed nor evaluated in the cited work.

3.1. Notation

Vectors are denoted by bold lowercase symbols ($\mathbf{x}$) and matrices by bold uppercase symbols ($\mathbf{X}$). The Euclidean norm is $\|\cdot\|$, the inner product $\langle \cdot, \cdot \rangle$, and the k -dimensional isotropic Gaussian $\mathcal{N}(\mu, \sigma^2 I_k)$. For positive integer m , $[m] = \{1, \dots, m\}$. Table 2 fixes the symbols specific to federated learning, the threat model, and the SyPrFL mechanism.

3.2. Federated Learning

Federated Learning is a distributed-optimization paradigm in which n clients collaboratively minimize the weighted global empirical risk $F(\theta) = \sum_{i=1}^n p_i F_i(\theta)$, where F_i is the local risk on dataset $\mathcal{D}_i$ and $p_i = |\mathcal{D}_i| / \sum_j |\mathcal{D}_j|$. Training proceeds in T synchronous rounds. At the start of round t , the server broadcasts the current global model $\theta^{(t)}$ and each client performs E epochs of local SGD with mini-batch size B , producing the update $\Delta_i^{(t)} = \theta_i^{(t)} - \theta^{(t)}$. The standard FedAvg aggregation [35] yields

$$\theta^{(t+1)} = \theta^{(t)} + \eta_t \sum_{i=1}^n p_i \Delta_i^{(t)}, \quad (1)$$

exposing every $\Delta_i^{(t)}$ to the server. SyPrFL replaces Eq. (1) with a trust-weighted secure aggregation in which the server observes neither the individual updates nor the trust weights of individual clients, only the weighted sum. Throughout the paper we work in the cross-silo regime ($n \in [20, 100]$, synchronous rounds, persistent clients), which matches the IoT-IDS gateway deployments described in Section 4.

3.3. Cryptographic and Privacy Primitives

Mask-based secure aggregation. SyPrFL builds on the mask-based secure aggregation protocol of Bonawitz et al. [36]. Each client holds a Diffie–Hellman keypair and derives, with every other client, a shared pseudo-random seed under DDH. Pairwise masks computed from these seeds are added with

opposite signs across each client pair so that they cancel under summation. Each client C_i transmits the masked update

$$\hat{\Delta}_i^{(t)} = \Delta_i^{(t)} + \sum_{j \in \mathcal{C} \setminus \{i\}} m_{i,j}, \quad m_{i,j} + m_{j,i} = 0, \quad (2)$$

allowing the server to recover the population sum $\sum_i \hat{\Delta}_i^{(t)} = \sum_i \Delta_i^{(t)}$ without observing any individual update. Under DDH and an honest-but-curious server colluding with fewer than $n/2$ clients, the joint view of the corrupted parties is computationally indistinguishable from a view in which honest clients submit independent uniform random vectors, conditioned on the legitimate aggregate. Dropouts are tolerated by Shamir-sharing the seeds among clients; the analysis of Section 7 assumes a zero dropout budget for clarity, with the standard extension applying otherwise.

Differential privacy and the Gaussian mechanism. SyPrFL uses central (ϵ, δ) -differential privacy [37] as a formal guarantee on the low-dimensional projections the server uses for Sybil detection. A randomized mechanism $\mathcal{M}$ satisfies (ϵ, δ) -DP if its output distribution on any two neighboring inputs differs by at most a factor of e^ϵ up to additive δ . The Gaussian mechanism instantiates this guarantee by adding noise $\xi \sim \mathcal{N}(0, \sigma^2 I_k)$ to a function f of ℓ_2 -sensitivity $S_2(f)$, with the calibration

$$\sigma \geq \frac{S_2(f) \sqrt{2 \ln(1.25/\delta)}}{\epsilon}. \quad (3)$$

In SyPrFL, f is the random projection $f(\Delta_i) = \Pi \Delta_i \in \mathbb{R}^k$ and per-client ℓ_2 -clipping at norm C_p ensures $S_2(f) \leq \|\Pi\|_{\text{op}} \cdot C_p$. For tight tracking of cumulative privacy loss across T training rounds we use the Rényi DP accountant [38] with the subsampled Gaussian bound [39], converted to a final (ϵ_T, δ_T) guarantee at the end of training. Post-processing immunity ensures that all downstream

Table 2

Notation used throughout the paper.

Symbol	Meaning
Federated learning	
n	Number of participating clients
$\mathcal{C} = \{C_1, \dots, C_n\}$	Set of clients
S	Aggregating server
$\mathcal{D}_i$	Local dataset of client C_i
$ \mathcal{D}_i , p_i$	Local size and aggregation weight
T	Number of FL training rounds
E	Local SGD epochs per round
B	Local mini-batch size
η_t	Global learning rate at round t
d	Model parameter dimension
$\theta^{(t)} \in \mathbb{R}^d$	Global model at round t
$\Delta_i^{(t)} \in \mathbb{R}^d$	Update of C_i in round t
C_{clip}	Generic per-update ℓ_2 clipping bound
C_p, C_A	Clipping bound, projection and aggregation channel
T_{cal}	Length of the calibration phase (rounds)
Adversary model	
$B \subset \mathcal{C}$	Set of Sybil-controlled clients, $ B = f$
$\mathcal{H} = \mathcal{C} \setminus B$	Honest clients
G	Number of Sybil collusion groups
$g \subseteq B$	A single Sybil group, $ g \geq 2$
ρ_H	Honest non-IID separation floor (Def. 4)
ρ_S	Sybil coordination tightness (Def. 5)
SyPrFL mechanism	
$\Pi \in \mathbb{R}^{k \times d}$	Public projection matrix
k	Projection dimension, $k \ll d$
$P_i, \tilde{P}_i \in \mathbb{R}^k$	Raw and DP-noised projection
ϵ, δ	(ϵ, δ) -DP budget
σ	Gaussian DP noise scale
$C_g^{(t)}$	Intra-cluster cohesion of cluster g
$\tau^{(t)}$	Adaptive cohesion threshold
γ	Sybil-detection tightness factor
$w_i^{(t)} \in [0, 1]$	Trust weight of C_i in round t
m_{cl}	HDBSCAN minimum cluster size
$\mathcal{G}^{(t)}$	Round- t HDBSCAN partition of $[n]$
$\mathcal{F}^{(t)}$	Flagged clusters in round t , $\mathcal{F}^{(t)} \subseteq \mathcal{G}^{(t)}$
$v(k, \sigma)$	DP noise floor of the cohesion statistic, Eq. (9)
$\kappa(\rho_S, \rho_H)$	Residual-influence factor of detected Sybils, Eq. (26)
z	Gaussian noise multiplier $\sigma/S_2(f)$

Note. Roman C carries a subscript in every use: C_i is a client, $C_g^{(t)}$ a cluster-cohesion value, and C_{clip} (resp. C_p, C_A) a clipping bound. Calligraphic $\mathcal{C}$ denotes the client set. The cryptographic group of the Diffie-Hellman key exchange is written $\mathbb{G}$ to keep it distinct from G , the number of Sybil collusion groups.

computations on the noised projection (clustering, cohesion statistics, trust-weight assignment) introduce no additional privacy loss beyond that already accounted for in the projection step.

3.4. Detection Primitives

The SyPrFL Sybil test relies on three further primitives, presented together because they compose into a single detection pipeline.

Random projection. The Johnson-Lindenstrauss lemma [40] guarantees that a random Gaussian matrix $\Pi \in \mathbb{R}^{k \times d}$ with entries $\Pi_{j\ell} \sim \mathcal{N}(0, 1/k)$ and $k = \mathcal{O}(\log n)$ preserves all

pairwise Euclidean distances among n points up to multiplicative distortion $(1 \pm \epsilon_{\text{JL}})$ with high probability. For the cross-silo regime ($n \in [20, 100]$) a projection dimension of $k \in [32, 128]$ keeps distortion below $\epsilon_{\text{JL}} = 0.1$. Crucially for SyPrFL, the JL guarantee implies that the *ratio* of intra-Sybil to inter-honest distances in projection space is preserved up to a small constant, so coordination signatures present in $\mathbb{R}^d$ remain visible in $\mathbb{R}^k$. The matrix Π is generated once by the server and broadcast as a public parameter.

HDBSCAN clustering. Given the set of DP-noised projections $\{\tilde{P}_i\}_{i=1}^n \subset \mathbb{R}^k$, the server partitions them with HDBSCAN using a single hyperparameter m_{cl} , the minimum cluster size. HDBSCAN is chosen over DBSCAN or k -means for three reasons: it does not require the number of clusters G to be specified in advance (unknown to the server in our setting); it accommodates clusters of varying density (different Sybil groups exhibit different intra-group tightness); and it labels low-density singletons as noise rather than forcing them into clusters (matching the operational expectation that honest non-IID singletons should not trigger detection logic). We use $m_{\text{cl}} = 2$ throughout so that even small Sybil groups are candidates for detection. HDBSCAN runs in $\mathcal{O}(n^2)$ time, negligible at $n \leq 100$. The partition inherits the DP guarantee of the projection step by post-processing immunity.

Cluster-cohesion separation test. For a cluster $g \subseteq [n]$ of size at least 2, define the cluster cohesion as the mean pairwise distance

$$C_g = \frac{2}{|g|(|g| - 1)} \sum_{i < j, i, j \in g} \|\tilde{P}_i - \tilde{P}_j\|. \quad (4)$$

Honest non-IID clusters have larger C_g (genuinely different gradients); coordinated Sybil groups have smaller C_g (similar gradients by construction). SyPrFL flags a cluster as Sybil when

$$C_g < \tau^{(t)}/\gamma, \quad (5)$$

where $\tau^{(t)}$ is an adaptive baseline tracking the running honest-cluster cohesion and $\gamma > 1$ is a tightness factor. The update rule for $\tau^{(t)}$ and the choice of γ are given in Section 6. By Gaussian concentration, C_g deviates from its expectation by at most $\mathcal{O}(\sigma/\sqrt{|g|})$ with high probability, so the threshold in Eq. (5) can be placed between the expected honest and Sybil cohesions with vanishing error rates as $|g|$ grows. The full false-positive and false-negative analysis is deferred to Section 7.

4. System Model

The SyPrFL framework targets a federated network of IoT intrusion-detection gateways in which independent administrative entities collaboratively train a shared classifier without exchanging raw network telemetry. The system model formalizes the participants, the communication and cryptographic substrate they share, the per-round protocol

skeleton on which SyPrFL is built, and the operational assumptions under which its privacy and Sybil-resilience guarantees hold. The model is deliberately narrowed to the cross-silo regime, in which clients are gateway-class devices that remain online for the duration of training and are individually addressable through stable network identifiers; this matches the deployment characteristics of consortium-managed IoT-IDS far better than the cross-device regime of mobile keyboards or wearables.

4.1. Deployment Setting and Entities

Each gateway in a SyPrFL deployment is operated by an independent administrative entity such as a network operator, smart-building tenant, or managed security service provider. The gateway monitors a partition of global IoT traffic and must classify high-volume telemetry records in near-real time to detect botnet activity, denial-of-service attempts, and reconnaissance scans. The administrative entities collaborate on training because no single entity sees enough attack diversity to train a strong classifier in isolation. Yet none of them can centralize raw telemetry. Regulatory regimes such as GDPR, HIPAA, and NERC CIP prohibit cross-entity transfer of raw traffic. Competitive considerations make raw telemetry sharing operationally infeasible even where regulation would allow it.

A SyPrFL deployment comprises three classes of entities. The **clients** $C = \{C_1, \dots, C_n\}$ are n IoT-IDS gateways with $n \in [20, 100]$. Each client C_i owns a private local dataset D_i of labelled network-traffic records and holds a local copy of the current global model $\theta^{(t)} \in \mathbb{R}^d$. Clients are mutually distrustful; no client knows which others are honest, Sybil-controlled, or data-distribution-similar to its own. The **server** S is a single logical aggregating entity operated by a neutral coordinator, typically a consortium-managed cloud node, regulatory authority, or designated lead organization. The server is honest-but-curious in the sense formalized in the threat model: it follows the prescribed protocol exactly, but may inspect every message it receives in an attempt to infer information about individual clients. The **bulletin board** BB is an authenticated public endpoint that distributes once-and-for-all protocol parameters and broadcasts the global model each round. It is realized in practice via the server's TLS endpoint together with a transparency log, and constitutes no separate trust anchor beyond the server itself.

The communication and cryptographic substrate is fixed before training begins. Every ordered pair of parties communicates over a TLS 1.3 channel offering confidentiality, integrity, and authenticity, with a public fixed-bound round duration Δ_R guaranteeing in-round delivery. Every client and the server hold long-term signing keys registered with the consortium's certificate authority, used both for TLS authentication and for the Diffie-Hellman setup of the secure-aggregation protocol. Prior to the first FL round, the server publishes on BB a set of immutable public parameters. These are the projection matrix $\Pi \in \mathbb{R}^{k \times d}$, with entries $\Pi_{j\ell} \sim \mathcal{N}(0, 1/k)$; the per-update ℓ_2 -clipping

bounds $C_P, C_A > 0$; the DP noise scale σ , derived from the target (ϵ, δ) budget through Eq. (3); the Sybil-detection tightness factor $\gamma > 1$; the adaptive-threshold smoothing factor $\alpha \in (0, 1)$; and the HDBSCAN minimum cluster size $m_{cl} \geq 2$. Publishing Π rather than concealing it is deliberate: SyPrFL derives no security benefit from a secret projection and gains auditability from a public one.

4.2. Per-Round Protocol Skeleton

Fig. 1 shows the SyPrFL architecture at a glance. Training proceeds in T synchronous rounds, each comprising five phases labelled (A)–(E) for later reference. The phases are described here at a high level; the full algorithmic specification, including the DP-PCC primitive, is given in Section 6.

Phase A (Broadcast). The server posts the current global model $\theta^{(t)}$ to the bulletin board. Each client retrieves $\theta^{(t)}$, verifies the signature, and initializes its local model to $\theta_i \leftarrow \theta^{(t)}$.

Phase B (Local training). Each client performs E epochs of local SGD on D_i with mini-batch size B , obtaining its local model $\theta_i^{(t)}$ and the update $\Delta_i^{(t)} = \theta_i^{(t)} - \theta^{(t)}$. The update is ℓ_2 -clipped:

$$\Delta_i^{(t)} \leftarrow \Delta_i^{(t)} \cdot \min\left(1, \frac{C_{\text{clip}}}{\|\Delta_i^{(t)}\|}\right). \quad (6)$$

Clipping bounds the ℓ_2 -sensitivity of the projection mechanism required by the Gaussian DP calibration of Eq. (3), without altering the update direction. The generic bound C_{clip} is instantiated per channel: the projection is formed from the update clipped at C_P and the masked submission from the same update clipped at C_A , with $C_A < C_P$ for the reasons set out in Section 8.2. Because the two clipped vectors are positive scalar multiples of one and the same $\Delta_i^{(t)}$, they carry identical direction, and the channel-binding property relied on in Section 5.1 is unaffected: a client cannot choose the direction it presents for detection independently of the direction it contributes to the aggregate.

Phase C (Encoding and submission). Each client computes, from the same clipped update, a DP-noised projection $\tilde{P}_i^{(t)} = \Pi \Delta_i^{(t)} + \xi_i^{(t)}$ with $\xi_i^{(t)} \sim \mathcal{N}(0, \sigma^2 I_k)$, and a masked full update $\hat{\Delta}_i^{(t)} = \Delta_i^{(t)} + \sum_{j \neq i} m_{i,j}$ via the pairwise masks from Section 3.3. Both submissions are sent to the server. Because the two derivatives come from the same $\Delta_i^{(t)}$, a malicious client cannot present a benign projection while smuggling a malicious masked update, a property exploited in the threat model.

Phase D (Sybil detection and trust assignment). The server clusters the received projections via HDBSCAN, computes the cohesion statistic $C_g^{(t)}$ for each non-trivial cluster, compares it against the adaptive threshold $\tau^{(t)}/\gamma$ via Eq. (5), and assigns a trust weight $w_i^{(t)} \in [0, 1]$ to every client. Trust weights are the sole bridge between the public-projection channel and the encrypted aggregation channel.

Phase E (Weighted secure aggregation). The server combines the masked updates with the trust weights via a weighted-sum extension of secure aggregation, obtaining

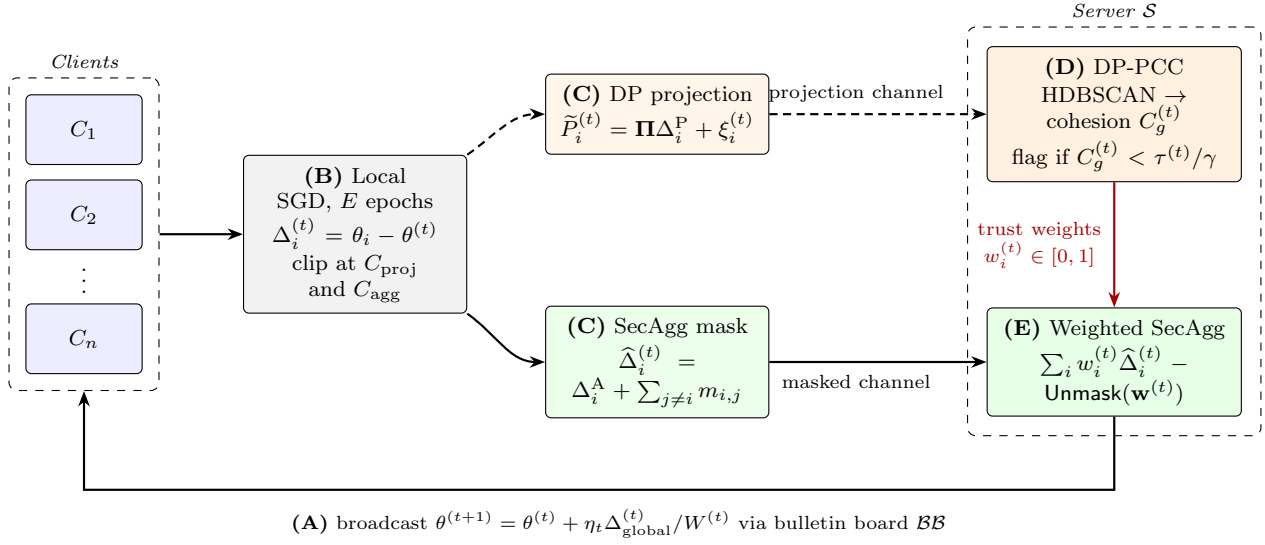


Fig 1: SyPrFL system architecture and the five phases of one training round. **(A)** The server broadcasts $\theta^{(t)}$ via the bulletin board. **(B)** Each client runs E local SGD epochs and clips the resulting update $\Delta_i^{(t)}$. **(C)** From that same clipped update the client derives two messages: the DP-noised projection $\tilde{P}_i^{(t)} = \Pi \Delta_i^{(t)} + \xi_i^{(t)}$ on the detection channel, and the SecAgg-masked $\hat{\Delta}_i^{(t)}$ on the aggregation channel. **(D)** The server clusters the projections with HDBSCAN, scores cohesion, and assigns trust weights $w_i^{(t)}$ - the only quantity that crosses between the two channels. **(E)** Weighted secure aggregation combines the masked updates under those weights and unmask the result. The server never observes an individual $\Delta_i^{(t)}$ in either channel.

the aggregate $\Delta_{\text{global}}^{(t)}$. The new global model is computed as

$$\theta^{(t+1)} = \theta^{(t)} + \eta_t \frac{\Delta_{\text{global}}^{(t)}}{\sum_{i=1}^n w_i^{(t)}}, \quad (7)$$

and is broadcast in Phase A of the next round.

A subtle but essential property of the protocol is that each client submits two derivatives of the same local update rather than one. The projection enables Sybil detection without revealing the update; the masked update enables full-fidelity aggregation of the surviving updates. The binding between the two is enforced by the algorithm of Section 6: a malicious client that submits a benign projection but a malicious masked update gains nothing, because the trust weight derived from the projection is applied multiplicatively to the masked contribution before the server decodes the population sum.

5. Threat Model

SyPrFL is designed to remain secure and useful in the face of two independent and simultaneous adversary classes. The first is a Sybil-Byzantine client adversary that statically corrupts a minority of clients and partitions them into coordinated collusion groups; this adversary aims to degrade model utility, induce mispredictions, or implant backdoors through arbitrary protocol messages. The second is an honest-but-curious server that follows the protocol

exactly but inspects every message it receives in an attempt to recover individual honest clients' updates or training data. We assume non-collusion between the two: the Sybil controller and the curious server pursue independent objectives and do not exchange information outside the protocol. Because this assumption carries real weight, we justify it on three grounds rather than asserting that it is conventional.

The first is that it is not merely convenient but *necessary for the problem to be well posed*. If the server colludes with the Sybil controller, no server-side aggregation rule whatsoever can provide robustness, SyPrFL included: the server is the party that computes the trust weights, so a colluding server simply assigns $w_i^{(t)} = 1$ to every Sybil and discards the detector's output. This is not a limitation of the two-channel design but a boundary of the entire class of server-side defenses, shared by FoolsGold, Krum, FLTrust and every robust aggregation rule in Section 2. Robustness against a colluding server requires a different trust model altogether - verifiable aggregation with client-side or public auditing which we identify as future work rather than claim.

The second is deployment structure. In the consortium-managed cross-silo setting of Section 4.1, the aggregator is operated by a neutral coordinator, a regulatory authority, or a designated lead organization, and is contractually and often legally distinct from the member organizations whose gateways participate. Sybil corruption, by contrast, arises from an adversary who compromises member organizations

or manufactures identities through weak IoT device authentication. The two roles are held by different entities under different incentives, which is what the assumption encodes.

The third is that the assumption is partially enforceable rather than purely stipulated. The trust-weight vector $\mathbf{w}^{(t)}$ and the cohesion statistics $\{C_g^{(t)}\}$ are published on the bulletin board $\mathcal{BB}$ each round. Any client can therefore recompute the flagging decision from the public projections and the public parameters, and detect a server that assigns weights inconsistent with its own inputs. This does not prevent collusion, but it makes a colluding server's deviation publicly attributable after the fact, which is the standard accountability posture for consortium infrastructure and materially raises the cost of the attack. The remainder of this section formalizes the two adversary classes, catalogues the concrete attack instantiations exercised in the experiments, and states the operational assumptions under which the guarantees hold.

5.1. Adversary Classes

Definition 1 (Sybil-Byzantine client adversary). *A Sybil-Byzantine adversary $\mathcal{A}_S$ is a probabilistic polynomial-time algorithm that, prior to training, statically corrupts a subset $B \subset \mathcal{C}$ with $|B| = f < n/2$, partitioned into $G \geq 1$ disjoint Sybil groups $B = g_1 \sqcup \dots \sqcup g_G$ with $|g_r| \geq 2$. In every round each $C_i \in B$ may replace its prescribed pair $(\tilde{P}_i^{(t)}, \hat{\Delta}_i^{(t)})$ with an arbitrary pair, possibly adapting to previously published global models, subject only to syntactic checks; members of a group coordinate through an out-of-band channel.*

The adversary has full protocol knowledge, including the public parameters $(\Pi, C_P, C_A, \sigma, \gamma, \alpha)$, the global model $\theta^{(t)}$ at every round, and the distribution from which honest updates are drawn. Within each group, members may share local data, agree on a common malicious update strategy, and exchange intermediate computations; across groups, coordination is not assumed. The adversary cannot break the cryptographic primitives of Section 3.3, deliver out-of-window messages, corrupt or impersonate clients outside B , or observe internal randomness of honest clients.

A subtle aspect of this capability is that the adversary may submit a benign-looking projection $\tilde{P}_i^{\text{mal}}$ paired with an unrelated malicious masked update $\hat{\Delta}_i^{\text{mal}}$. This projection-update decoupling is the most dangerous strategy available within the model, since it attempts to defeat the binding between the two channels. SyPrFL counters it by applying trust weights multiplicatively to masked shares before unmasking, so that a low projection-derived trust weight automatically damps any malicious masked contribution regardless of its content; the formal argument is Theorem 8. The robustness goal is that for every compliant adversary, the SyPrFL aggregate $\Delta_{\text{global}}^{(t)} / \sum_i w_i^{(t)}$ remains within a bounded deviation from the honest mean $\bar{\Delta}_H^{(t)} = |\mathcal{H}|^{-1} \sum_{i \in \mathcal{H}} \Delta_i^{(t)}$, with the deviation vanishing as $\rho_S / \rho_H \rightarrow 0$ and the detection-failure probability controlled by γ .

Definition 2 (Honest-but-curious server adversary). *An honest-but-curious adversary $\mathcal{A}_P$ statically corrupts the*

server S together with a coalition $\mathcal{T} \subseteq \mathcal{H}$ of honest clients with $|\mathcal{T}| \leq t < n/2$. Corrupted parties follow the prescribed protocol exactly but record the entire view available to them and attempt to recover information about any honest client's local data $\mathcal{D}_i$ or individual updates $\{\Delta_i^{(t)}\}_{t \in [T]}$ for some $i \in \mathcal{H} \setminus \mathcal{T}$, beyond what is directly implied by the legitimate protocol output.

The recorded view comprises the sequence $\{\tilde{P}_i^{(t)}, \hat{\Delta}_i^{(t)}\}_{i \in \mathcal{C}, t \in [T]}$

of received messages, the broadcast models $\{\theta^{(t)}\}_{t \in [T]}$, the bulletin-board contents, the full HDBSCAN partition and cohesion-statistic history, the trust-weight history, and the coalition's own Diffie–Hellman secret keys and pairwise masks. The adversary cannot collude with $\mathcal{A}_S$, deviate from the prescribed computations, inject extra messages, or break the cryptographic primitives.

SyPrFL counters this adversary through a hybrid privacy mechanism. On the masked-update channel, the standard secure-aggregation argument under DDH ensures that the corrupted parties' view of any individual $\hat{\Delta}_i^{(t)}$ is computationally indistinguishable from a uniform random vector. On the projection channel, the Gaussian mechanism ensures that the view of any individual $\tilde{P}_i^{(t)}$ satisfies (ϵ, δ) -DP per round, composing across T rounds via the Rényi DP accountant. The two channels operate on the same underlying $\Delta_i^{(t)}$ but reveal disjoint linear functionals of it: the projection reveals a k -dimensional summary protected by DP, while the masked update reveals nothing per-client and only the aggregate in combination. The formal guarantee is Theorem 2.

5.2. Concrete Attack Instantiations

The abstract adversary above is instantiated through six concrete attack strategies that together form the empirical evaluation suite of Section 8.

(A1) *Single-group consistent Sybil.* A single Sybil group $g_1 = B$ with $|g_1| = f$ adopts the classical poisoning strategy: every member submits the same malicious update $\hat{\Delta}_i^{(t)} = \Delta^{\text{tgt}} \in \mathbb{R}^d$ drawn from a distribution that pulls the aggregate toward a target direction. The intra-group projection cohesion is at the noise floor of the DP mechanism, the extreme tight-cluster regime.

(A2) *Multi-group independent Sybils.* The malicious set B is partitioned into $G \geq 2$ disjoint groups operated by independent attackers. Each group internally produces a consistent malicious update, but the target directions differ across groups. The attack tests whether the detector handles multiple simultaneous Sybil groups rather than only the largest one.

(A3) *Noisy Sybils.* Aware of cohesion-based detection, the adversary adds intra-group noise to defeat naive tightness tests. Each $C_i \in g_r$ submits $\hat{\Delta}_i^{(t)} = \Delta_r^{\text{tgt}} + v_i$ with $v_i \sim \mathcal{N}(0, \sigma_{\text{nz}}^2 I_d)$. As σ_{nz} grows, ρ_S increases and the group becomes harder to flag; the attack succeeds only when σ_{nz}

is large enough to hide the group while small enough to still pull the aggregate.

(A4) *Adaptive projection-aware Sybils.* The adversary exploits its knowledge of the public matrix $\mathbf{\Pi}$ to craft updates whose projections are deliberately spread out, injecting malicious signal that lies largely in the kernel of $\mathbf{\Pi}$ and is therefore invisible to the detector. Each $C_i \in g_r$ solves

$$\begin{aligned} \tilde{\Delta}_i^{(t)} \in \arg \max_{\mathbf{z} \in \mathbb{R}^d} \mathcal{L}(\mathbf{z}; \theta^{(t)}, \Delta_r^{\text{tgt}}) \\ \text{s.t. } \|\mathbf{\Pi}\mathbf{z} - \mathbf{\Pi}\tilde{P}_r\| \geq \eta_{\text{spread}}, \end{aligned} \quad (8)$$

where $\mathcal{L}$ is the adversary's loss-degradation objective, $\tilde{P}_r$ is a coordinated reference projection, and η_{spread} enforces a minimum intra-group projection spread. This is the strongest attack in the suite and tests the limit of cohesion-based detection.

(A5) *Mixed Sybil and Byzantine.* A portion of $\mathcal{B}$ executes coordinated Sybils as in A1, while the remainder executes independent classical Byzantine attacks (sign-flipping, additive Gaussian noise). The mix tests whether the Sybil-specific mechanism gracefully degrades to the level of a standard robust aggregator on the non-Sybil portion, rather than mistakenly clustering independent attackers together.

(A6) *Sybil-driven backdoor.* Following the model replacement strategy, the Sybil group $g_1 = \mathcal{B}$ scales each update by a boost factor $n/|\mathcal{B}|$ to embed a backdoor on a targeted sub-class (for example, misclassifying Mirai traffic as benign). The boost inflates per-update magnitude but the intra-group projection cohesion remains characteristically tight under coordination.

5.3. Operational Assumptions

The analyses of Section 7 rely on four operational assumptions, realistic for the cross-silo IoT-IDS deployments of Section 8.

Definition 3 (Synchronous participation). *Every client submits both $\tilde{P}_i^{(t)}$ and $\hat{\Delta}_i^{(t)}$ within the round duration Δ_R . Dropouts are a deployment-level robustness concern handled by the standard secret-shared mask reconstruction, and do not weaken the analyses.*

Definition 4 (Bounded honest non-IID heterogeneity). *There exists a constant $\rho_H > 0$ such that, in every round, the minimum pairwise Euclidean distance between any two honest clients' projected updates $\|\mathbf{\Pi}\Delta_i^{(t)} - \mathbf{\Pi}\Delta_j^{(t)}\|$ is at least ρ_H . The constant ρ_H is determined by the non-IID-ness of the client-data partition rather than by the protocol; Section 8.4 reports measured estimates of ρ_H , together with the estimator used to obtain them.*

Definition 5 (Sybil coordination tightness). *Each Sybil group $g \subseteq \mathcal{B}$ exhibits coordination tightness $\rho_S > 0$ such that, with high probability, the maximum pairwise distance between projected updates within g is at most ρ_S . A Sybil*

group is detectable when $\rho_S < \rho_H$; the strength of the detection guarantee in Section 7 depends quantitatively on the ratio ρ_S/ρ_H . This characterizes effective Sybils rather than restricting the adversary: a coordinated attack with $\rho_S \geq \rho_H$ is no more effective than an equal number of uncoordinated random attackers, which the weighted aggregate already averages out.

Definition 6 (Honest majority). *The honest set satisfies $|\mathcal{H}| > n/2$. This is standard in Byzantine federated learning and is necessary independently of SyPrFL: no aggregation rule can recover from a malicious majority without external information.*

6. The SyPrFL Algorithm

The SyPrFL protocol composes four mechanisms into a single per-round procedure. Local clipped training bounds the ℓ_2 -sensitivity of every subsequent operation. A public random projection $\mathbf{\Pi} \in \mathbb{R}^{k \times d}$, followed by a Gaussian DP mechanism, produces a low-dimensional differentially-private summary of each client's update. Mask-based secure aggregation conceals the individual full-dimensional updates from the server. Finally, the DP-PCC Sybil-detection primitive examines the cluster structure of the projections and outputs a trust weight $w_i^{(t)} \in [0, 1]$ for every client. That weight is applied multiplicatively to the client's masked contribution, before the population-level unmasking.

The design rationale is that Sybil detection is fundamentally a question about the relational geometry of client updates, not about their individual content. By moving the entire detection computation onto a public, low-dimensional, DP-noised projection, SyPrFL preserves the privacy of individual updates while retaining enough relational information to identify coordinated groups. The masked-update channel then carries the information required for high-fidelity aggregation, with the trust weights from the projection channel acting as the only bridge between the two. The remainder of this section formalizes the DP-PCC primitive, the per-round client and server procedures, the weighted secure-aggregation construction, the adaptive-threshold rule, and the per-round complexity.

6.1. Design Rationale: Why Two Channels, and Why DP-PCC

Reviewers of an earlier version asked, reasonably, whether the two-channel architecture is more than an engineering convenience and whether DP-PCC is more than the composition of a random projection, HDBSCAN, and a mean pairwise distance. This subsection answers both questions before the construction is specified, because the answers determine why the construction takes the form it does.

6.1.1. The single-channel obstruction

Call a per-round protocol *single-channel* if every client sends exactly one message M_i derived from its update Δ_i , and the server derives from $\{M_i\}_{i=1}^n$ both the aggregate it applies to the model and the relational statistic it uses

for detection. Every Sybil-aware aggregation rule we are aware of FoolsGold, Krum, Multi-Krum, and the similarity-filtering IoT-IDS defenses of Section 2 is single-channel in this sense. The following proposition shows that the class cannot deliver both properties, so the failure observed empirically in Section 9 is structural rather than a deficiency of any particular rule.

Proposition 1 (Single-channel obstruction). *Let Π_1 be a single-channel protocol whose server view admits an estimator $\hat{D}$ of the honest pairwise distance matrix $D_{ij} = \|\Delta_i - \Delta_j\|$, $i, j \in \mathcal{H}$, with uniform additive resolution η , i.e. $\max_{i,j} |\hat{D}_{ij} - D_{ij}| \leq \eta$ with probability $1 - o(1)$. Fix a detection task that must separate a Sybil group with tightness ρ_S from honest clients with separation floor $\rho_H > \rho_S$. Then for $|\mathcal{H}| = h \geq 3$:*

1. **(Detection requires resolution.)** *If $\eta \geq (\rho_H - \rho_S)/2$, then no test measurable with respect to the server view distinguishes the Sybil configuration from an honest configuration with total-variation advantage bounded away from 0; the optimal test errs with probability at least $1/2 - o(1)$.*
2. **(Resolution destroys privacy.)** *If $\eta < (\rho_H - \rho_S)/2$, the server view determines the honest configuration $\{\Delta_i\}_{i \in \mathcal{H}}$ up to a rigid motion of $\mathbb{R}^d$, with per-point error $\mathcal{O}(\eta\sqrt{h})$. Consequently the view is not simulatable from the aggregate $\sum_i \Delta_i$ alone, and Π_1 does not realize the secure-aggregation ideal functionality.*

Proof. Part 1 is the standard two-point argument. Choose the honest configuration $\mathcal{X}_H$ and the Sybil configuration $\mathcal{X}_S$ so that their distance matrices differ entrywise by exactly $\rho_H - \rho_S$ on the pairs internal to the candidate group and agree elsewhere. If the view resolves distances only to $\eta \geq (\rho_H - \rho_S)/2$, the two induced view distributions have overlapping supports at every entry, and a coupling exists under which the two views are identical with probability $1 - o(1)$; no measurable test separates them beyond that coupling error.

Part 2 is classical multidimensional scaling. Let $\hat{D}^{(2)}$ be the entrywise square of $\hat{D}$ and $J = I_h - \frac{1}{h}\mathbf{1}\mathbf{1}^\top$ the centering matrix. Double centering gives the Gram matrix $\hat{G} = -\frac{1}{2}J\hat{D}^{(2)}J$, whose eigendecomposition returns a configuration $\{\hat{\Delta}_i\}$ with $\|\hat{\Delta}_i - Q\Delta_i - b\| = \mathcal{O}(\eta\sqrt{h})$ for some orthogonal Q and translation b , by Weyl's inequality applied to $\hat{G} - G$ (whose entries are perturbed by $\mathcal{O}(\eta \max_{i,j} D_{ij})$). The residual ambiguity is exactly the rigid motion (Q, b) , which the server resolves using information it already holds: it knows $\theta^{(t)}$, can evaluate a reference gradient on public data to fix the rotation, and knows $\sum_i \Delta_i$ to fix the translation. A simulator given only $\sum_i \Delta_i$ cannot reproduce a view carrying h individually localized updates, since the aggregate is invariant to any permutation or mean-preserving redistribution of its summands while the view is not. Hence no simulator exists and the ideal functionality is not realized. $\square$

Proposition 1 isolates the design constraint precisely. Privacy and Sybil detection are incompatible only when the

same representation carries both. SyPrFL therefore gives the server two representations of Δ_i that are deliberately unequal in what they reveal. On the projection channel the server sees $\Pi\Delta_i + \xi_i$, so the multidimensional-scaling reconstruction of Part 2 recovers a configuration in $\mathbb{R}^k$ rather than $\mathbb{R}^d$: every component of Δ_i in the $(d - k)$ -dimensional kernel of Π is information-theoretically absent from the view, and the k retained coordinates are released under the Gaussian mechanism. With $k = 64$ and $d \approx 7.2 \times 10^4$, the reconstruction is uninformative about 99.9% of the update's coordinates before DP noise is even considered. On the aggregation channel the server sees a masked share that is computationally indistinguishable from uniform. Neither channel alone supports the reconstruction of Part 2, and the trust weights, which are the only quantity crossing between them, are a function of the projection channel only. This is the sense in which the two-channel split is not an implementation detail: it is the minimal structure that evades an obstruction which provably binds every single-channel design.

6.1.2. DP-PCC as a primitive, not a composition

The DP-PCC primitive of Section 6.2 is easy to mis-read as “random projection, then HDBSCAN, then mean pairwise distance”. That composition, applied naively, does not work, for a reason that is quantitative rather than aesthetic.

First, a mean-pairwise-distance test is not a valid cohesion test under differential privacy. Adding $\xi_i \sim \mathcal{N}(0, \sigma^2 I_k)$ to each projection inflates every pairwise distance by a common floor. Writing $\eta_{ij} = \xi_i - \xi_j \sim \mathcal{N}(0, 2\sigma^2 I_k)$ and using the concentration of the norm of a Gaussian vector,

$$\mathbb{E} \|\delta_{ij} + \eta_{ij}\| = \sqrt{\|\delta_{ij}\|^2 + v(k, \sigma)^2} (1 + o(1)), \quad (9)$$

$$v(k, \sigma) \triangleq \sigma\sqrt{2k},$$

where $\delta_{ij} = \Pi(\Delta_i - \Delta_j)$ is the noiseless separation. At the operating point of Section 8 ($k = 64$) the floor v exceeds the honest separation ρ_H measured in Section 8.4 by a factor of 8.8 ($v = 5.66$ against a mean $\rho_H = 0.642$). An absolute threshold on C_g therefore has power tending to zero: both honest and Sybil clusters sit on the same noise pedestal. DP-PCC is defined instead as a comparison of $C_g^{(t)}$ against a baseline $\tau^{(t)}$ estimated from the same noised channel in the same round, so that $v(k, \sigma)$ enters both sides of Eq. (5) and cancels to first order. The primitive is thus a self-normalizing statistic, and the cancellation made explicit in Lemma 4 is what makes detection possible at all under DP. This is the technical content that a projection-plus-clustering composition does not have.

Second, the baseline is adaptive rather than fixed. Honest cohesion drifts downward over training as the global model converges and client updates shrink; a constant threshold calibrated in round 1 flags the entire population by round 20. The exponential moving average of Eq. (15) tracks this drift, using the median rather than the mean so that a Sybil cluster present during estimation cannot drag the baseline toward itself while the honest majority assumption holds.

Third, the output is a cryptographically bindable weight vector, not a label. A clustering pipeline returns a partition, which is actionable only if the server can act on individual plaintext updates exactly what SyPrFL forbids. DP-PCC returns $(w_1^{(t)}, \dots, w_n^{(t)}) \in [0, 1]^n$ specifically so that it can be consumed by the weighted secure-aggregation construction of Section 6.4, which applies the weights to masked shares. Detection and enforcement are therefore separated across the two channels, and the interface between them is a real-valued weight rather than an identity. Removing any one of these three elements the self-normalizing statistic, the adaptive baseline, or the weight-valued output breaks the protocol, which is the operational sense in which DP-PCC is a primitive rather than a pipeline.

6.1.3. Scope of the priority claim

The claim that SyPrFL is the first protocol to combine (ϵ, δ) -DP, secure aggregation of full updates, and provable Sybil-group detection is a claim about the surveyed literature, and we state it with that scope. Two kinds of evidence support it. The first is the audit of Table 1 together with the prose survey of Section 2: among the closest works, every entry that provides cryptographic privacy either omits Sybil resilience entirely or provides it only through a plaintext-side anomaly detector, and every entry with an explicit Sybil mechanism operates on plaintext updates. The second is Proposition 1, which explains why that cell is empty rather than merely observing that it is: a protocol occupying it must be at least two-channel, and no prior work in the surveyed set separates its detection representation from its aggregation representation. We do not claim an impossibility result covering all conceivable constructions - general-purpose secure multi-party computation or fully homomorphic encryption could evaluate a similarity oracle inside the ciphertext at a cost we discuss in Section 9.8 and the claim is stated throughout as being to the best of our knowledge over protocols that avoid such machinery.

6.2. The DP-PCC Primitive

DP-PCC takes as input the n differentially-private projections $\{\tilde{P}_i^{(t)}\}_{i=1}^n \subset \mathbb{R}^k$ submitted in Phase C of round t , together with the adaptive baseline $\tau^{(t)}$ carried over from previous rounds, and returns a vector of trust weights $(w_1^{(t)}, \dots, w_n^{(t)}) \in [0, 1]^n$ and an updated baseline $\tau^{(t+1)}$. The procedure has four steps.

The server first runs HDBSCAN on the set $\{\tilde{P}_i^{(t)}\}_{i=1}^n$ with minimum cluster size $m_{cl} \geq 2$, obtaining the partition $\mathcal{G}^{(t)} = \{g_1^{(t)}, \dots, g_{|\mathcal{G}^{(t)}|}^{(t)}, \text{noise}^{(t)}\}$ of $[n]$ into clusters of size at least m_{cl} together with a residual noise set of points unassigned to any cluster. Fig. 2 illustrates this clustering outcome, showing tight clusters of Sybil-controlled projections alongside dispersed honest clients.

For each cluster $g \in \mathcal{G}^{(t)}$ with $|g| \geq 2$, the server then computes the cohesion statistic

$$C_g^{(t)} = \frac{2}{|g|(|g| - 1)} \sum_{i < j, i, j \in g} \|\tilde{P}_i^{(t)} - \tilde{P}_j^{(t)}\|. \quad (10)$$

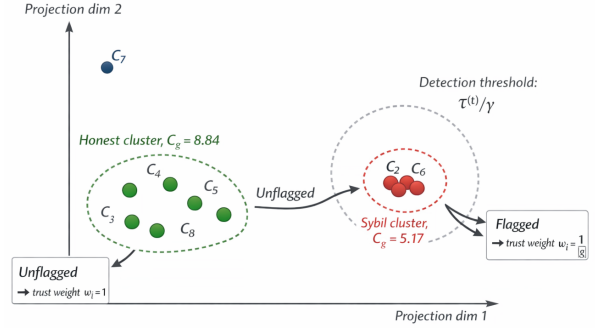


Fig 2: Server-side HDBSCAN clustering and cohesion test for Sybil detection.

A cluster is flagged as a suspected Sybil group when $C_g^{(t)} < \tau^{(t)}/\gamma$, where $\tau^{(t)}$ is the round- t baseline and $\gamma > 1$ is the public tightness factor; let $\mathcal{F}^{(t)} \subseteq \mathcal{G}^{(t)}$ denote the flagged set. Finally, for each client C_i the server assigns the trust weight

$$w_i^{(t)} = \begin{cases} \frac{1}{|g|}, & i \in g \text{ for some } g \in \mathcal{F}^{(t)}, \\ 1, & \text{otherwise.} \end{cases} \quad (11)$$

An unflagged client retains full trust weight; a member of a flagged Sybil group of size $|g|$ has its effective contribution reduced by a factor of $|g|$, so that the entire group exerts at most the influence of a single honest client. Clients in $\text{noise}^{(t)}$ are treated as honest singletons by default, on the basis that an attacker who fails to coordinate is not detectable by relational geometry and is no more dangerous than an equal number of independent random attackers. The primitive returns the trust-weight vector together with the set of cohesion values $\{C_g^{(t)}\}$ used to update the baseline.

6.3. Client and Server Procedures

Algorithms 1 and 2 formalize the two sides of a SyPrFL round. Fig. 3 illustrates the per-client encoding pipeline, showing how the same clipped local update $\Delta_i^{(t)}$ simultaneously feeds the DP-noised projection and the SecAgg-masked submission.

Two design points warrant attention. The noise $\xi_i^{(t)}$ is freshly sampled per round, ensuring that the projection channel satisfies (ϵ, δ) -DP per round under the calibration of Eq. (3); composition across T rounds is handled by the Rényi DP accountant. The same clipped update $\Delta_i^{(t)}$ feeds both the projection and the masked submission, so a malicious client cannot submit a benign projection alongside a malicious masked update without having its trust weight derived from its own projection: the server applies $w_i^{(t)}$ to the same $\hat{\Delta}_i^{(t)}$ that the client submitted, regardless of what the client placed in the masked channel.

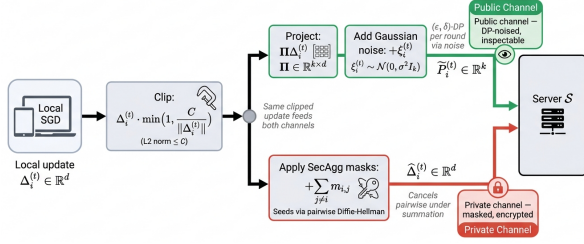


Fig 3: One clipped update $\Delta_i^{(t)}$ feeds both the DP-noised projection with masked submission, preventing channel decoupling.

Algorithm 1 SyPrFL Client Procedure (round t , client C_i)

Require: Global model $\theta^{(t)}$; local dataset D_i ; params $(\Pi, C_P, C_A, \sigma, \{pk_j\}_{j \neq i})$

Ensure: $(\tilde{P}_i^{(t)}, \hat{\Delta}_i^{(t)})$ to S

- 1: $\theta_i \leftarrow \theta^{(t)}$
- 2: **for** $e = 1$ **to** E **do**
- 3: Local SGD epoch on D_i , batch B , update θ_i
- 4: **end for**
- 5: $\Delta_i^{(t)} \leftarrow \theta_i - \theta^{(t)}$
- 6: $\Delta_i^P \leftarrow \Delta_i^{(t)} \min(1, C_P / \|\Delta_i^{(t)}\|)$ $\triangleright$ clip for detection
- 7: $\Delta_i^A \leftarrow \Delta_i^{(t)} \min(1, C_A / \|\Delta_i^{(t)}\|)$ $\triangleright$ clip for aggregation
- 8: $\xi_i^{(t)} \sim \mathcal{N}(0, \sigma^2 I_k)$
- 9: $\tilde{P}_i^{(t)} \leftarrow \Pi \Delta_i^P + \xi_i^{(t)}$ $\triangleright$ DP projection
- 10: **for** each $j \in \mathcal{C} \setminus \{i\}$ **do**
- 11: $s_{i,j} \leftarrow H(pk_j^{sk_i})$ $\triangleright$ shared seed
- 12: $m_{i,j} \leftarrow s_{i,j}$ **if** $i < j$ **else** $-s_{j,i}$
- 13: **end for**
- 14: $\hat{\Delta}_i^{(t)} \leftarrow \Delta_i^A + \sum_{j \neq i} m_{i,j}$ $\triangleright$ masked update
- 15: **Send** $(\tilde{P}_i^{(t)}, \hat{\Delta}_i^{(t)})$ to S

6.4. Weighted Secure Aggregation

A non-trivial component of SyPrFL is the construction that allows the server to compute a weighted sum of masked updates without seeing any individual $\Delta_i^{(t)}$ and without requiring clients to know their own weights in advance. Standard SecAgg computes the unweighted sum $\sum_i \Delta_i^{(t)}$ via pairwise masks $m_{i,j} + m_{j,i} = 0$ that cancel under summation. Two naive extensions fail: asking each client to multiply its update by $w_i^{(t)}$ before submission fails because the weights are computed by the server only after receiving the projections, and asking the server to multiply $\hat{\Delta}_i^{(t)}$ by $w_i^{(t)}$ on its side fails because the asymmetric weights break the pairwise mask cancellation and the result is corrupted by an uncontrolled residual mask term.

SyPrFL resolves this by exploiting the linearity of the masking operation. For arbitrary scalars $\{w_i\}_{i=1}^n$,

$$\sum_{i=1}^n w_i \hat{\Delta}_i^{(t)} = \sum_{i=1}^n w_i \Delta_i^{(t)} + \sum_{i=1}^n \sum_{j \neq i} w_i m_{i,j}. \quad (12)$$

Algorithm 2 SyPrFL Server Procedure (round t)

Require: Messages $\{\tilde{P}_i^{(t)}, \hat{\Delta}_i^{(t)}\}_{i=1}^n$; baseline $\tau^{(t)}$; params (γ, α, m_{cl})

Ensure: Updated $\theta^{(t+1)}$; updated $\tau^{(t+1)}$

- 1: $\mathcal{G}^{(t)} \leftarrow \text{HDBSCAN}(\{\tilde{P}_i^{(t)}\}_{i=1}^n, m_{cl})$
- 2: **for** each cluster $g \in \mathcal{G}^{(t)}$ with $|g| \geq 2$ **do**
- 3: $C_g^{(t)} \leftarrow \text{Eq. (10)}$
- 4: **end for**
- 5: $\mathcal{F}^{(t)} \leftarrow \{g \in \mathcal{G}^{(t)} : C_g^{(t)} < \tau^{(t)} / \gamma\}$
- 6: **for** $i = 1$ **to** n **do**
- 7: Assign $w_i^{(t)}$ by Eq. (11)
- 8: **end for**
- 9: $S^{(t)} \leftarrow \sum_{i=1}^n w_i^{(t)} \hat{\Delta}_i^{(t)}$
- 10: $\Delta_{\text{global}}^{(t)} \leftarrow S^{(t)} - \text{Unmask}(\mathbf{w}^{(t)})$ $\triangleright$ Def. 7, Eq. (13)
- 11: $W^{(t)} \leftarrow \sum_{i=1}^n w_i^{(t)}$
- 12: $\theta^{(t+1)} \leftarrow \theta^{(t)} + \eta_t \Delta_{\text{global}}^{(t)} / W^{(t)}$
- 13: $\tau^{(t+1)} \leftarrow \alpha \tau^{(t)} + (1 - \alpha) \text{median}(\{C_g^{(t)}\})$
- 14: **return** $\theta^{(t+1)}, \tau^{(t+1)}$

The second term is no longer zero, but it depends only on the public weights $\{w_i\}$ and the pairwise mask seeds $\{s_{i,j}\}$, and is therefore reconstructible by the server through the same secret-share opening mechanism that standard SecAgg uses for dropout recovery. Define the per-pair residual $R_{i,j} = (w_i - w_j) s_{i,j}$ for $i < j$; a short calculation shows that the residual term in Eq. (12) equals $\sum_{i < j} R_{i,j}$. The server, knowing the weights $\{w_i^{(t)}\}$ and having collected reconstruction shares of every $s_{i,j}$ from the non-dropout clients, evaluates this sum and subtracts it. We name that evaluation explicitly, since Algorithm 2 invokes it as a subroutine.

Definition 7 (Weighted unmasking). *Let $\{s_{i,j}\}_{i < j} \subset \mathbb{R}^d$ be the pairwise seed-derived mask vectors of the round, recovered by the server through the standard SecAgg threshold-reconstruction procedure, and let $\mathbf{w} = (w_1, \dots, w_n) \in [0, 1]^n$ be the trust weights. The weighted unmasking function $\text{Unmask} : [0, 1]^n \rightarrow \mathbb{R}^d$ is*

$$\text{Unmask}(\mathbf{w}) \triangleq \sum_{1 \leq i < j \leq n} (w_i - w_j) s_{i,j} = \sum_{1 \leq i < j \leq n} R_{i,j}. \quad (13)$$

It is a deterministic, public function of the weight vector and the reconstructed seeds; it takes no client update as input, and it is identically $\mathbf{0}$ when all weights are equal, recovering standard SecAgg as the special case $\mathbf{w} = \mathbf{1}$.

Substituting Definition 7 into Eq. (12) gives the server's output:

$$\begin{aligned} \Delta_{\text{global}}^{(t)} &= \sum_{i=1}^n w_i^{(t)} \hat{\Delta}_i^{(t)} - \sum_{i < j} R_{i,j}^{(t)} \\ &= \sum_{i=1}^n w_i^{(t)} \Delta_i^{(t)}. \end{aligned} \quad (14)$$

The server learns only the trust-weighted sum of individual updates, never an individual update. The construction trades

a small additional reconstruction cost (one Shamir recovery per pair) for the ability to apply server-side trust weights to the aggregate. The privacy guarantee is preserved because the openings of $s_{i,j}$ reveal no information beyond what the server already knows in standard SecAgg: under DDH, $s_{i,j}$ is computationally indistinguishable from uniform random for any party other than C_i and C_j , and the population reconstruction proceeds via the same threshold mechanism as in the original construction.

Worked example. Because the cancellation is the least obvious step of the protocol, we trace it through a complete round with $n = 4$ clients and a deliberately small model dimension $d = 2$, so that every vector can be written out. Suppose clients C_3 and C_4 are a flagged Sybil pair, so $\mathbf{w} = (1, 1, \frac{1}{2}, \frac{1}{2})$ and $W = \sum_i w_i = 3$. Let the clipped updates and the six pairwise seeds be

$$\begin{aligned} \Delta_1 &= (2, 0), & \Delta_2 &= (0, 2), & \Delta_3 &= \Delta_4 = (4, 4), \\ s_{1,2} &= (1, 0), & s_{1,3} &= (0, 1), & s_{1,4} &= (1, 1), \\ s_{2,3} &= (2, 0), & s_{2,4} &= (0, 2), & s_{3,4} &= (1, -1). \end{aligned}$$

With $m_{i,j} = s_{i,j}$ for $i < j$ and $m_{i,j} = -s_{j,i}$ for $i > j$, each client submits $\hat{\Delta}_i = \Delta_i + \sum_{j \neq i} m_{i,j}$:

$$\hat{\Delta}_1 = (4, 2), \quad \hat{\Delta}_2 = (1, 4), \quad \hat{\Delta}_3 = (3, 2), \quad \hat{\Delta}_4 = (2, 2).$$

None of these reveals its underlying update; note in particular that $\hat{\Delta}_3 \neq \hat{\Delta}_4$ even though $\Delta_3 = \Delta_4$, so the masked channel does not expose the Sybil pair. The unweighted sum is $\sum_i \hat{\Delta}_i = (10, 10) = \sum_i \Delta_i$, the standard SecAgg guarantee. The weighted sum, however, does not cancel:

$$\sum_i w_i \hat{\Delta}_i = (4, 2) + (1, 4) + \frac{1}{2}(3, 2) + \frac{1}{2}(2, 2) = (7.5, 8),$$

whereas the target is $\sum_i w_i \Delta_i = (2, 0) + (0, 2) + \frac{1}{2}(4, 4) + \frac{1}{2}(4, 4) = (6, 6)$. The gap $(1.5, 2)$ is exactly what Definition 7 recovers. Only the four pairs that straddle the weight boundary contribute:

$$\begin{aligned} \text{Unmask}(\mathbf{w}) &= \underbrace{(w_1 - w_2)s_{1,2}}_{(0,0)} + \underbrace{(w_1 - w_3)s_{1,3}}_{(0,0.5)} \\ &\quad + \underbrace{(w_1 - w_4)s_{1,4}}_{(0.5,0.5)} + \underbrace{(w_2 - w_3)s_{2,3}}_{(1,0)} \\ &\quad + \underbrace{(w_2 - w_4)s_{2,4}}_{(0,1)} + \underbrace{(w_3 - w_4)s_{3,4}}_{(0,0)} \\ &= (1.5, 2). \end{aligned}$$

Subtracting gives $\Delta_{\text{global}} = (7.5, 8) - (1.5, 2) = (6, 6) = \sum_i w_i \Delta_i$ exactly, and the model update is $\Delta_{\text{global}}/W = (2, 2)$. Two properties of the construction are visible in the arithmetic. Pairs with equal weights contribute nothing, so in the common case where only a small flagged group is down-weighted the server reconstructs $\mathcal{O}(|g|n)$ seeds rather

than all $\binom{n}{2}$. And the Sybil pair, contributing $\frac{1}{2}(4, 4)$ each, together exerts the influence of a single client submitting $(4, 4)$, which is precisely the suppression that Eq. (11) is designed to produce and that Theorem 8 quantifies in general.

6.5. Adaptive Threshold and Complexity

The baseline $\tau^{(t)}$ adapts each round to track the natural drift in cluster cohesion that arises as the global model converges. We use an exponential moving average of the median (rather than mean) per-round cohesion, to remain robust to outlier clusters:

$$\tau^{(t+1)} = \alpha \tau^{(t)} + (1 - \alpha) \text{median}(\{C_g^{(t)} : g \in \mathcal{G}^{(t)}, |g| \geq 2\}), \quad (15)$$

with smoothing factor $\alpha \in (0, 1)$ and an initial baseline $\tau^{(0)}$ derived during a short calibration phase ($t \in \{1, \dots, T_{\text{cal}}\}$, typically $T_{\text{cal}} = 5$) in which no Sybil flagging occurs and all clients receive $w_i^{(t)} = 1$. The calibration phase lets $\tau^{(t)}$ estimate the natural non-IID cohesion baseline before any flagging is activated. The median-based update retains robustness even if some Sybil cohesion values are accidentally included during calibration, provided the Sybil fraction does not exceed one half the honest-majority assumption of Definition 6. The tightness factor γ controls the false-positive versus false-negative trade-off: larger γ requires a Sybil cluster to be very tight relative to the baseline before being flagged (low false positives, higher false negatives), while smaller γ flags more aggressively. We treat γ as a deployment-time hyperparameter and study its sensitivity empirically; the formal calibration in terms of ρ_S and ρ_H is given in Theorem 3.

The per-round communication cost is dominated by the masked update at $\mathcal{O}(d)$ per client plus a small $\mathcal{O}(k)$ projection vector, matching the cost of plain FedAvg up to the additional projection submission - negligible when $k = \mathcal{O}(\log n) \ll d$. The dominant server-side cost is $\mathcal{O}(n^2 d)$ in the weighted-aggregation residual reconstruction, which is the same asymptotic cost incurred by standard SecAgg under dropout recovery and is well within the budget of consortium-managed cloud infrastructure for the cross-silo regime $n \leq 100$. The HDBSCAN clustering on n points in $\mathbb{R}^k$ runs in $\mathcal{O}(n^2 k)$, sub-millisecond at $n \leq 100$. Table 3 summarizes the per-phase costs.

The algorithm just specified is the operational instantiation of the dual-channel design previewed in Section 4.2: the projection channel carries the relational signal needed for Sybil detection under differential privacy, the masked channel carries the full-fidelity updates needed for aggregation under SecAgg, and the trust weights derived from the DP-PCC primitive bind the two through the weighted aggregation construction of Eq. (14). What remains is to establish that this composition delivers the guarantees the design promises: that no adversary compliant with Definition 2 can recover an honest client's update beyond the (ϵ, δ) -DP and SecAgg leakage, that DP-PCC detects coordinated Sybil groups with bounded error as a function of $\rho_S/\rho_H, k$,

Table 3

Per-round communication and computation complexity of SyPrFL. n : clients; d : model dimension; k : projection dimension ($k \ll d$); B, E : local batch size and epochs.

Phase	Comm. per client	Server compute	Notes
Local training (B)	–	–	$\mathcal{O}(BED)$ at each client
Projection & noise (C, projection channel)	$\mathcal{O}(k)$	$\mathcal{O}(nk)$	One k -dim vector per client
Masking & submission (C, mask channel)	$\mathcal{O}(d)$	–	Pairwise masks pre-derived
HDBSCAN (D, Step 1)	–	$\mathcal{O}(n^2k)$	Cluster n points in $\mathbb{R}^k$
Cohesion & flagging (D, Steps 2–3)	–	$\mathcal{O}(n^2)$	Eq. (10) per cluster pair
Weighted secure aggregation (E)	$\mathcal{O}(n)$	$\mathcal{O}(n^2d)$	Residual reconstruction
Update broadcast (A, $t+1$)	$\mathcal{O}(d)$	–	Broadcast of $\theta^{(t+1)}$

and σ , and that the resulting aggregate converges to a useful global model despite the trust weighting. The next section establishes each of these properties in turn.

7. Security and Convergence Analysis

The composition of differentially-private projections, weighted secure aggregation, and the DP-PCC primitive yields three formal guarantees that together justify the SyPrFL design. Privacy holds against the honest-but-curious server of Definition 2 by a hybrid argument that replaces the masked channel under the DDH assumption and the projection channel under the Gaussian-mechanism guarantee. Sybil detection holds against the adversary of Definition 1 through a Gaussian-concentration argument on the cluster cohesion statistic, with false-positive and false-negative rates that decay exponentially in the cluster size. Robustness and convergence follow from the detection guarantee: detected Sybils are suppressed to the influence of a single honest client, undetected Sybils contribute a residual bias that scales with the false-negative rate, and the aggregate converges at the standard $\mathcal{O}(1/\sqrt{T})$ rate up to lower-order terms. The proofs below are presented in their working detail; technical sub-claims that follow standard constructions are stated and cited rather than re-derived.

7.1. Privacy

Theorem 2 (Privacy of SyPrFL). *Let $\mathcal{A}_P$ be an honest-but-curious adversary that corrupts the server S together with at most $t < n/2$ clients $\mathcal{T} \subset \mathcal{H}$. Under the DDH assumption on the group $\mathbb{G}$ underlying SecAgg and the Gaussian-mechanism calibration of Eq. (3), the joint view of $\mathcal{A}_P$ across T rounds of SyPrFL satisfies*

$$\left| \Pr[\mathfrak{D}(\text{View}) = 1] - \Pr[\mathfrak{D}(\text{Sim}(\text{out})) = 1] \right| \leq \text{negl}(\lambda) + \epsilon_{\text{DP}}(T) \quad (16)$$

for every probabilistic polynomial-time distinguisher $\mathfrak{D}$, where λ is the cryptographic security parameter and $\epsilon_{\text{DP}}(T)$ is the cumulative T -round Gaussian-mechanism privacy loss computed via the Rényi DP accountant.

Proof. We construct a simulator Sim given only the legitimate protocol outputs $\{\theta^{(t)}, \{w_i^{(t)}\}_{i=1}^n\}_{t \in [T]}$ and show

indistinguishability from the real view by a hybrid argument across two intermediate experiments.

In hybrid H_0 , the adversary observes the real SyPrFL transcript: for every $t \in [T]$, the received messages are $\{\tilde{P}_i^{(t)}, \hat{\Delta}_i^{(t)}\}_{i=1}^n$, the broadcast $\theta^{(t)}$, the HDBSCAN partition, the cohesion statistics, and the trust weights.

In hybrid H_1 , for every $i \in \mathcal{H} \setminus \mathcal{T}$ and every $t \in [T]$ we replace the masked update $\hat{\Delta}_i^{(t)}$ with a uniform random vector $\mathbf{u}_i^{(t)} \sim \text{Uniform}(\mathbb{F}_q^d)$, subject to the constraint that the population sum after unmasking is unchanged. By the SecAgg argument, this replacement is computationally indistinguishable from H_0 under DDH:

$$\left| \Pr[\mathfrak{D}(H_0) = 1] - \Pr[\mathfrak{D}(H_1) = 1] \right| \leq \text{negl}(\lambda). \quad (17)$$

The weighted-aggregation construction of Section 6.4 preserves this property because the residual term in Eq. (14) is deterministically derived from the public weights and the seeds opened by the standard SecAgg recovery procedure; no additional information about $\Delta_i^{(t)}$ is revealed.

In hybrid H_2 , for every $i \in \mathcal{H} \setminus \mathcal{T}$ and every $t \in [T]$ we replace the noised projection $\tilde{P}_i^{(t)} = \Pi \Delta_i^{(t)} + \xi_i^{(t)}$ with a fresh sample $\tilde{P}_i^{\text{sim}} \sim \mathcal{M}_G(\mathbf{0})$ from the Gaussian mechanism applied to the zero vector. By the (ϵ, δ) -DP guarantee and the post-processing immunity of the projection channel, this replacement loses at most ϵ in distinguishing advantage per round on the projection associated with any single client, and at most $\epsilon_{\text{DP}}(T)$ across the T -round composition by the RDP accountant:

$$\left| \Pr[\mathfrak{D}(H_1) = 1] - \Pr[\mathfrak{D}(H_2) = 1] \right| \leq \epsilon_{\text{DP}}(T). \quad (18)$$

In H_2 , the only honest-client-dependent content remaining in the transcript is the legitimate output $\{\theta^{(t)}, \{w_i^{(t)}\}\}$, which Sim has by assumption. Combining Eqs. (17)–(18) via the triangle inequality yields Eq. (16). $\square$

The Gaussian mechanism is calibrated to a per-round (ϵ, δ) -DP target via Eq. (3); the cumulative loss over T rounds is $\epsilon_{\text{DP}}(T) = \mathcal{O}(\epsilon \sqrt{T \ln(1/\delta)})$ under tight RDP accounting.

Because reviewers asked both for the numerical budget and for the reconciliation of the two training horizons that appear in this paper, we state both here. The two horizons play different roles and are not alternatives. *All reported*

Table 4

Cumulative DP budget ϵ_T at $\delta = 10^{-5}$ under Rényi accounting, as a function of the noise multiplier $z = \sigma/S_2(f)$. The reported experiments use $T = 30$; $T = 200$ is the horizon of the asymptotic convergence discussion only.

Noise multiplier z	Per-round ϵ	$\epsilon_{T=30}$	$\epsilon_{T=200}$
9.69	0.50	2.48	7.35
4.84	1.00	5.45	17.21
2.42	2.00	12.49	43.58

experimental results use $T = 30$ rounds, which is the horizon of Section 8 and the horizon at which every number in Section 9 was obtained; 30 rounds suffice because all eleven defenses converge within 20 rounds on these datasets. The value $T = 200$ appears only in the asymptotic illustration of Eq. (29), where the $\mathcal{O}(1/\sqrt{T})$ term is compared against the non-vanishing adversarial term, a comparison that is uninformative at small T . To remove the ambiguity, we quote the privacy budget at both horizons.

Writing $z = \sigma/S_2(f)$ for the noise multiplier, with $S_2(f) \leq \|\Pi\|_{\text{op}} C_P$ the projection sensitivity of Section 3.3, Table 4 reports the cumulative (ϵ_T, δ) guarantee at $\delta = 10^{-5}$ under the Rényi accountant with the tightened conversion. At the calibrated operating point (per-round $\epsilon = 0.5$, i.e. $z = 9.69$), the experiments reported in Section 9 carry a cumulative budget of $\epsilon_{30} = 2.48$. The corresponding figure at the asymptotic horizon is $\epsilon_{200} = 7.35$, which supersedes the approximate value of 7.8 quoted in the previous version of this paper; the difference is the tightened RDP-to-DP conversion, not a change of mechanism. A budget of $\epsilon \approx 2.5$ at $\delta = 10^{-5}$ is at the conservative end of what DP-FedAvg deployments report, and it is worth noting why SyPrFL can afford it: the budget is spent on a 64 -dimensional projection used only for trust weighting, not on the 7.2×10^4 -dimensional update that is actually aggregated.

The budget interacts with detection exactly as Corollary 5 predicts, and the interaction is the central privacy–utility tension of the design. Decreasing z (more noise per unit sensitivity) buys a smaller ϵ_T but enters the detection bound at the fourth power, so the guarantee degrades far faster than the budget improves. Increasing z sharpens detection but spends budget linearly in $\sqrt{T}$. Because the noised channel never touches the aggregation path, however, model utility is insensitive to this choice over the range we examined: the DP noise perturbs which clients are down-weighted, not the values that are summed, which is why the clean-accuracy cost of SyPrFL in Table 10 is roughly a third of that of DP-FedAvg at a comparable budget.

7.2. Sybil Detection

Theorem 3 (DP-PCC Detection Bounds). *Let $g \subseteq [n]$ be a cluster of size $|g| \geq m_{\text{cl}}$ produced by HDBSCAN in round t . Define the false-positive event FP as g being flagged when g consists entirely of honest clients, and the false-negative event FN as g not being flagged when g is a Sybil group of intra-group coordination tightness $\rho_S < \rho_H$. Then, under*

Definitions 4 and 5:

$$\Pr[\text{FP}] \leq 2 \exp\left(-\frac{|g|(\mu_H - \tau^{(t)}/\gamma)^2}{2\sigma^2}\right), \quad (19)$$

$$\Pr[\text{FN}] \leq 2 \exp\left(-\frac{|g|(\tau^{(t)}/\gamma - \mu_S)^2}{2\sigma^2}\right), \quad (20)$$

where μ_H, μ_S are the expected cohesion of an honest cluster and a Sybil cluster respectively, satisfying $\mu_H \geq \rho_H$ and $\mu_S \leq \rho_S + \sigma\sqrt{2k}(1 + o(1))$.

Proof. Both bounds follow from the Gaussian cohesion concentration inequality. Conditional on g being honest, the projections $\{P_i = \Pi\Delta_i\}_{i \in g}$ satisfy the non-IID floor of Definition 4, so the expected cohesion $\mathbb{E}[C_g] = \mu_H \geq \rho_H$. The flagging event FP occurs when $C_g < \tau^{(t)}/\gamma$, with $\tau^{(t)}/\gamma < \mu_H$ by the calibration of Section 6.5; applying Gaussian concentration with $u = \mu_H - \tau^{(t)}/\gamma > 0$ yields Eq. (19). Conditional on g being a Sybil cluster, the projections satisfy Definition 5 and the expected cohesion is $\mathbb{E}[C_g] = \mu_S \leq \rho_S + \sigma\sqrt{2k}(1 + o(1))$, where the second term arises from the Gaussian-noise floor. The failure-to-flag event FN occurs when $C_g \geq \tau^{(t)}/\gamma$, with $\tau^{(t)}/\gamma > \mu_S$ by the assumed detectability condition $\rho_S < \rho_H$; applying the same inequality with $u = \tau^{(t)}/\gamma - \mu_S > 0$ yields Eq. (20). $\square$

Both bounds are exponential in $|g|$ and decay quickly with cluster size. Stated in the form above, however, they leave the projection dimension k implicit inside μ_S , and a reviewer of an earlier version correctly observed that the dependence on k deserves to be quantitative, since k is a design parameter the operator must choose. We therefore make it explicit. The key structural fact is that the DP noise contributes a common pedestal to every pairwise distance, honest and Sybil alike, and that this pedestal cancels because the threshold is estimated from the same noised channel.

Lemma 4 (Noise floor and its cancellation). *Let $\delta_{ij} = \Pi(\Delta_i - \Delta_j)$ be the noiseless projected separation of clients i, j , and let $v(k, \sigma) = \sigma\sqrt{2k}$ be the noise floor of Eq. (9). Then, as $k \rightarrow \infty$,*

$$\mathbb{E}\|\tilde{P}_i - \tilde{P}_j\| = \sqrt{\|\delta_{ij}\|^2 + v(k, \sigma)^2} (1 + \mathcal{O}(k^{-1})), \quad (21)$$

so that the expected cohesions of an honest and of a Sybil cluster are $\mu_H = \sqrt{\rho_H^2 + v^2} (1 + o(1))$ and $\mu_S = \sqrt{\rho_S^2 + v^2} (1 + o(1))$ respectively. Their separation is

$$\mu_H - \mu_S = \frac{\rho_H^2 - \rho_S^2}{\sqrt{\rho_H^2 + v^2} + \sqrt{\rho_S^2 + v^2}} \xrightarrow{v \gg \rho_H} \frac{\rho_H^2 - \rho_S^2}{2\sigma\sqrt{2k}}. \quad (22)$$

Moreover $C_g^{(t)}$, viewed as a function of the independent noise vectors $\{\xi_i\}_{i \in g}$, is Lipschitz with constant $2/\sqrt{|g|}$, so by Gaussian concentration $\Pr[|C_g^{(t)} - \mathbb{E}C_g^{(t)}| \geq u] \leq 2 \exp(-|g|u^2/(8\sigma^2))$.

Proof. For $\eta_{ij} = \xi_i - \xi_j \sim \mathcal{N}(0, 2\sigma^2 I_k)$ we have $\mathbb{E}\|\delta_{ij} + \eta_{ij}\|^2 = \|\delta_{ij}\|^2 + 2\sigma^2 k$, and the norm of a k -dimensional Gaussian concentrates about its mean with relative fluctuation $\mathcal{O}(k^{-1/2})$, so Jensen's gap is $\mathcal{O}(k^{-1})$ after taking the square root; this is Eq. (21), and Eq. (22) follows by rationalizing the difference of square roots. For the Lipschitz constant, perturbing a single ξ_i by v changes each of the $|g| - 1$ pairs containing i by at most $\|v\|$, and $C_g^{(t)}$ weights each pair by $2/(|g|(|g| - 1))$, giving a per-coordinate-block constant $2/|g|$; aggregating over the $|g|$ independent blocks gives $\sqrt{|g| \cdot (2/|g|)^2} = 2/\sqrt{|g|}$. Gaussian concentration for Lipschitz functions then gives the stated tail. $\square$

Lemma 4 is the formal content behind the design argument of Section 6.1.2: the pedestal $v(k, \sigma)$ appears in μ_H and μ_S alike and is removed by comparing against the adaptively estimated $\tau^{(t)}$, while what survives is the separation of Eq. (22). Placing the threshold at the midpoint, $\tau^{(t)}/\gamma = (\mu_H + \mu_S)/2$, and substituting into the tail bound yields the explicit form we need.

Corollary 5 (Detection error as a function of k). *In the DP-dominated regime $\sigma\sqrt{2k} \gg \rho_H$, with the threshold placed at the midpoint of μ_S and μ_H ,*

$$\max(\Pr[\text{FP}], \Pr[\text{FN}]) \leq 2 \exp\left(-\frac{|g|(\rho_H^2 - \rho_S^2)^2}{256 \sigma^4 k}\right). \quad (23)$$

Three consequences follow, and they are the practical reason the protocol fixes $k = 64$. First, detection error degrades *monotonically in k* : every additional projection coordinate adds noise to the cohesion statistic without adding coordination signal, because coordination is a rank-one property of the group that any k above the Johnson–Lindenstrauss floor already resolves. The operator should therefore choose the *smallest* k for which the JL distortion guarantee of Section 3.4 still holds, $k = \mathcal{O}(\log n)$, which for $n \in [20, 100]$ is the range $k \in [32, 128]$; $k = 64$ sits at the geometric centre of that window. Second, the bound is quartic in σ and only linear in k , so the noise scale, not the projection dimension, is the dominant lever. Third and we state this plainly because it bears on how the empirical results should be read Eq. (23) is a worst-case bound and is numerically informative only when σ is small. Table 5 evaluates it at the empirical $\rho_H = 0.642$ measured in Section 8.4, with $\rho_S/\rho_H = 0.3$ and $|g| = 3$.

At the operating point used in the experiments ($\sigma = 0.5$, $k = 64$) the bound is vacuous for groups of size three, yet detection succeeds empirically (Section 9.5). The discrepancy is not a contradiction, and it is worth being explicit about its source, because it delimits what the theorem does and does not certify. Eq. (23) bounds the error of a test that sees only the scalar $C_g^{(t)}$, whereas the deployed detector first runs HDBSCAN, which exploits the full k -dimensional density structure and the mutual-reachability geometry rather than a single averaged distance. The bound is also worst-case over adversary configurations at a given ρ_S , while attacks

Table 5

Worst-case detection-error bound of Eq. (23) at the measured $\rho_H = 0.642$, $\rho_S/\rho_H = 0.3$, group size $|g| = 3$. Entries ≥ 1 are vacuous. The guarantee tightens as k decreases and sharply as σ decreases.

Noise scale	Projection dimension k			
	16	32	64	128
$\sigma = 0.05$	1.4×10^{-7}	5.3×10^{-4}	0.032	0.255
$\sigma = 0.10$	0.714	vacuous	vacuous	vacuous
$\sigma = 0.50$	vacuous	vacuous	vacuous	vacuous

A1, A2 and A6 realize ρ_S near zero, where the achieved margin is much larger than the $\rho_S/\rho_H = 0.3$ assumed here. Theorem 3 and Corollary 5 should therefore be read as a sufficient condition a regime of $(k, \sigma, |g|)$ in which detection is guaranteed outright and not as a characterization of when detection succeeds. Closing this gap, by analysing the density-based clustering step rather than treating it as a black box, is the most substantial piece of theory this work leaves open, and we return to it in Section 9.8.

7.3. The Calibration Phase as an Attack Window

During the first T_{cal} rounds SyPrFL sets $w_i^{(t)} = 1$ for every client so that $\tau^{(t)}$ can estimate the honest cohesion level before flagging is switched on. This is a genuine window of vulnerability, and the analysis above does not cover it. We treat it here explicitly. The window admits two distinct attacks, which we bound separately: unfiltered poisoning of the model, and manipulation of the baseline that the detector will subsequently rely on.

Unfiltered poisoning. Because no client is down-weighted, every malicious update enters the aggregate at full strength for T_{cal} rounds. The damage is nevertheless bounded, because updates are clipped. Each of the f malicious clients contributes at most C_A in ℓ_2 -norm and the aggregate is normalized by $W^{(t)} = n$, so the per-round displacement away from the honest trajectory is at most $\eta_t f C_A/n$, and after the whole window

$$\|\theta^{(T_{\text{cal}})} - \theta_{\text{honest}}^{(T_{\text{cal}})}\| \leq T_{\text{cal}} \eta \frac{f}{n} C_A. \quad (24)$$

At the deployment parameters of Section 8 ($T_{\text{cal}} = 5$, $\eta = 1$, $f/n = 0.30$, $C_A = 15$) this is at most 22.5. The essential point is that this is a bounded perturbation of the *initialization* of the defended phase, not a persistent bias: Theorem 9 depends on the starting point only through the initial gap $F(\theta^{(0)}) - F^*$, which by L -smoothness increases by at most $\frac{L}{2}(T_{\text{cal}} \eta f C_A/n)^2$. The calibration window therefore inflates the $\mathcal{O}(1/\sqrt{T})$ term by a constant factor and leaves the asymptotic rate and the size of the stationary neighbourhood unchanged. It cannot implant a persistent backdoor for the same reason: the defended rounds that follow apply the honest majority's gradient signal to whatever model the window produced.

Baseline manipulation. The subtler attack is to shape $\tau^{(0)}$ itself. Deflating the baseline lowers the flagging threshold $\tau^{(t)}/\gamma$ and lets a Sybil group evade detection later; inflating it raises the threshold and turns the detector into a denial-of-service tool against honest clients. The median in Eq. (15) is what limits this, and the limit is exactly the classical breakdown point.

Proposition 6 (Calibration robustness). *Let $v_t = |\{g \in \mathcal{G}^{(t)} : |g| \geq 2\}|$ be the number of non-trivial clusters in calibration round t , and let s_t be the number of these that contain at least one Sybil. If $s_t < v_t/2$ for every $t \leq T_{\text{cal}}$, then*

$$\min_{g \text{ honest}} C_g \leq \tau^{(0)} \leq \max_{g \text{ honest}} C_g, \quad (25)$$

irrespective of the values the adversary places in the cohesion statistics it controls.

Proof. The median of a multiset in which strictly fewer than half the elements are adversarial lies between the smallest and largest honest elements: moving any minority of points, even to $\pm\infty$, cannot push the median past the honest order statistics that bracket it. The exponential moving average of Eq. (15) is a convex combination of such medians and inherits the bracket. $\square$

Proposition 6 bounds the attack but does not eliminate it, and it is worth being precise about the residual exposure. Within the bracket of Eq. (25) the adversary can still drive $\tau^{(0)}$ toward $\min_g C_g$, and the empirical spread of honest cohesion measured in Section 8.4 is wide: ρ_H ranges over $[0.077, 1.891]$ across rounds and client pairs, with median 0.608. An adversary that succeeds in pinning the baseline at the low end of that range effectively multiplies the tightness factor γ by about 8, which is far more evasion room than the nominal $\gamma = 1.5$ suggests. Three deployment measures reduce this exposure, and we recommend all three. First, rate-limit the baseline: reject any single-round decrease of $\tau^{(t)}$ larger than a fixed fraction, so that driving the baseline down requires many rounds of consistent adversarial behaviour rather than one. Second, keep T_{cal} as short as estimation variance permits, since the window is the only period in which manipulation is unopposed. Third, where the deployment can supply it, seed $\tau^{(0)}$ from a server-side validation partition rather than from client submissions, which removes the window entirely at the cost of the root-dataset assumption that FLTrust also makes. A full game-theoretic treatment of the calibration window, in which the adversary optimizes jointly over its behaviour inside and outside the window, is beyond the scope of this paper and is stated as open in Section 9.8.

7.4. Robustness and Convergence

Theorem 8 below is stated in terms of a residual-influence factor κ . In the previous version this factor was introduced informally, and we now define and bound it, since it carries the entire dependence of the robustness guarantee on how tightly the adversary coordinates.

The residual influence of a *detected* group is not zero, because down-weighting suppresses a flagged cluster to the influence of one client rather than to nothing. It would be zero if every coordinated group were always recovered by HDBSCAN as a single cluster. The source of residual influence is precisely that it is not: a group whose internal spread ρ_S approaches the honest floor ρ_H may be split by HDBSCAN into several sub-clusters, each of which is then down-weighted *separately*, so that a group fragmented into m pieces retains the influence of m clients rather than one.

Definition 8 (Residual-influence factor). *For a Sybil group g with coordination tightness ρ_S , let $m(g)$ be the number of distinct clusters of $\mathcal{G}^{(t)}$ that intersect g and are flagged. Define*

$$\kappa(\rho_S, \rho_H) \triangleq \frac{C_A}{|\mathcal{H}| \sigma_H} \sum_{r=1}^G (\mathbb{E}[m(g_r)] - 1), \quad (26)$$

the excess influence, in units of the honest spread σ_H , that flagged groups retain beyond the one client's worth of influence that Eq. (11) intends to leave them.

Lemma 7 (Bound on κ). *Let m_{cl} be the HDBSCAN minimum cluster size. Then for every group g ,*

$$\mathbb{E}[m(g)] \leq \min \left\{ \left\lfloor \frac{|g|}{m_{\text{cl}}} \right\rfloor, \left(1 + \frac{2\rho_S}{\rho_H}\right)^k \right\}, \quad (27)$$

and consequently $\kappa(\rho_S, \rho_H) = 0$ whenever $\rho_S < \rho_H/2$. In general κ is non-decreasing in ρ_S/ρ_H and $\kappa \rightarrow 0$ as $\rho_S/\rho_H \rightarrow 0$.

Proof. The first term of the minimum is structural: HDBSCAN's excess-of-mass criterion never emits a cluster with fewer than m_{cl} points, so g cannot be split into more than $\lfloor |g|/m_{\text{cl}} \rfloor$ flagged pieces. The second is geometric. Two points of g are separated into different clusters only if some pair within g exceeds the mutual-reachability scale at which honest points are themselves separated, which by Definition 4 is at least ρ_H . The members of g lie in a ball of radius ρ_S by Definition 5, and a standard volumetric packing argument bounds the number of disjoint ρ_H -separated subsets of a ρ_S -ball in $\mathbb{R}^k$ by $(1 + 2\rho_S/\rho_H)^k$. When $\rho_S < \rho_H/2$ the diameter $2\rho_S$ of the group is strictly below ρ_H , so no internal pair can exceed the separation scale, the packing number is exactly 1, $m(g) = 1$ deterministically, and Eq. (26) vanishes term by term. Monotonicity in ρ_S/ρ_H is immediate from Eq. (27). $\square$

The sufficient condition $\rho_S < \rho_H/2$ is the useful form for deployment: as long as a Sybil group is at least twice as tight as the honest non-IID floor, the residual-influence term of Theorem 8 vanishes identically, and the entire robustness gap is carried by the false-negative term ϵ_{FN} . This also explains the attack ordering observed in Section 9.2: A1, A2 and A6 satisfy the condition comfortably, whereas A3 with σ_{nz} tuned to the honest floor is engineered to violate it, which is exactly where the empirical accuracy loss is largest.

Theorem 8 (Sybil-Resilience of SyPrFL Aggregation). *Under Definitions 1, 4, 5, 6, and the detection-failure bounds of Theorem 3, the SyPrFL aggregate satisfies*

$$\left\| \frac{\Delta_{\text{global}}^{(t)}}{\sum_{i=1}^n w_i^{(t)}} - \bar{\Delta}_{\mathcal{H}}^{(t)} \right\| \leq (\kappa(\rho_S, \rho_H) + \varepsilon_{\text{FN}}) \sigma_{\mathcal{H}} \quad (28)$$

with probability at least $1 - |\mathcal{G}^{(t)}| \max(\Pr[\text{FP}], \Pr[\text{FN}])$, where $\kappa(\rho_S, \rho_H)$ is the residual-influence factor of Definition 8, bounded in Lemma 7 and identically zero when $\rho_S < \rho_H/2$, and $\varepsilon_{\text{FN}} = \mathcal{O}(\Pr[\text{FN}] \cdot f/n)$.

Proof. Decompose the population into three disjoint sets: detected Sybils $\mathcal{B}_{\text{D}}$ (members of flagged clusters in $\mathcal{F}^{(t)}$), undetected Sybils $\mathcal{B}_{\text{U}} = \mathcal{B} \setminus \mathcal{B}_{\text{D}}$, and honest clients $\mathcal{H}$. By Eq. (11), every $i \in \mathcal{B}_{\text{D}}$ has trust weight $w_i^{(t)} = 1/|g_r|$ for its containing flagged group, while every $i \in \mathcal{B}_{\text{U}} \cup \mathcal{H}$ has $w_i^{(t)} = 1$ (modulo the probability- $\Pr[\text{FP}]$ event that an honest cluster is falsely flagged). For a flagged group of size $|g_r|$, the total trust-weighted contribution is $\frac{1}{|g_r|} \sum_{i \in g_r} \Delta_i^{(t)}$, which has the same total influence as a single honest update of comparable magnitude; summed over all $|\mathcal{F}^{(t)}|$ flagged groups, this contribution is bounded by $|\mathcal{F}^{(t)}| C_{\text{A}}$ in ℓ_2 -norm, where C_{A} is the aggregation-channel clipping bound. Undetected Sybils contribute $\sum_{i \in \mathcal{B}_{\text{U}}} \Delta_i^{(t)}$, bounded by $|\mathcal{B}_{\text{U}}| C_{\text{A}}$; their expected size is $|\mathcal{B}| \cdot \Pr[\text{FN}]$ by Theorem 3, giving the second term $\varepsilon_{\text{FN}} = \mathcal{O}(\Pr[\text{FN}] \cdot f/n)$. The honest contribution has mean $\bar{\Delta}_{\mathcal{H}}^{(t)}$ and spread bounded by $\sigma_{\mathcal{H}}$. Combining and normalizing by $\sum_i w_i^{(t)}$ yields Eq. (28); the deviation factor $\kappa(\rho_S, \rho_H)$ of Definition 8 accounts for flagged groups that HDBSCAN fragments into several separately down-weighted sub-clusters; by Lemma 7 it vanishes whenever $\rho_S < \rho_H/2$, so under that condition the bound reduces to $\varepsilon_{\text{FN}} \sigma_{\mathcal{H}}$. $\square$

Theorem 9 (Convergence of SyPrFL). *Let F be L -smooth and bounded below by F^* , let the stochastic gradients at every client be unbiased with variance at most σ_g^2 , and let $\|\nabla F_i(\theta)\| \leq G$ for all i and θ . Let each round run E local SGD steps at local rate η_{ℓ} with $\eta_{\ell} E L \leq \frac{1}{2}$, and let the global rate be $\eta_t = \eta/\sqrt{T}$. Under Definitions 4, 5, 6, and the robustness bound of Theorem 8 holding in every round, after T rounds:*

$$\min_{t \leq T} \mathbb{E} \left\| \nabla F(\theta^{(t)}) \right\|^2 \leq \mathcal{O}\left(\frac{1}{\sqrt{T}}\right) + \mathcal{O}((\kappa + \varepsilon_{\text{FN}})^2 \sigma_{\mathcal{H}}^2) + \mathcal{O}(\sigma_{\text{DP}}^2). \quad (29)$$

Proof. Write $g^{(t)} = \Delta_{\text{global}}^{(t)}/W^{(t)}$ for the normalized aggregate actually applied in Eq. (7), so that $\theta^{(t+1)} = \theta^{(t)} + \eta_t g^{(t)}$, and let $\bar{\Delta}_{\mathcal{H}}^{(t)}$ denote the honest mean update. The proof has four steps.

Step 1 (decomposition of the applied direction). Split

$$g^{(t)} = \underbrace{-\eta_{\ell} E \nabla F(\theta^{(t)})}_{\text{descent term}} + \underbrace{e^{(t)}}_{\text{client drift}} + \underbrace{\zeta^{(t)}}_{\text{stochastic noise}} + \underbrace{b^{(t)}}_{\text{adversarial bias}}, \quad (30)$$

where $e^{(t)} = \bar{\Delta}_{\mathcal{H}}^{(t)} + \eta_{\ell} E \nabla F(\theta^{(t)}) - \zeta^{(t)}$ collects the deviation of the honest mean from a single exact gradient step, $\zeta^{(t)}$ is the zero-mean sampling noise, and $b^{(t)} = g^{(t)} - \bar{\Delta}_{\mathcal{H}}^{(t)}$. Three bounds apply. By Theorem 8, $\|b^{(t)}\| \leq (\kappa + \varepsilon_{\text{FN}}) \sigma_{\mathcal{H}} \triangleq B$ on the event of probability $1 - p_t$, $p_t = |\mathcal{G}^{(t)}| \max(\Pr[\text{FP}], \Pr[\text{FN}])$, and $\|b^{(t)}\| \leq 2C_{\text{A}}$ always, since both the aggregate and the honest mean are averages of vectors clipped at C_{A} ; hence $\mathbb{E}\|b^{(t)}\| \leq B + 2C_{\text{A}}p_t$. By the standard local-drift bound for E steps of SGD on an L -smooth objective with G -bounded gradients, $\|e^{(t)}\| \leq \eta_{\ell}^2 E^2 L G$. Finally $\mathbb{E}\|\zeta^{(t)}\|^2 \leq \eta_{\ell}^2 E \sigma_g^2 / |\mathcal{H}|$, the averaging over the honest population being valid because undetected Sybils are already accounted for inside $b^{(t)}$.

Step 2 (descent inequality). L -smoothness gives

$$F(\theta^{(t+1)}) \leq F(\theta^{(t)}) + \eta_t \langle \nabla F(\theta^{(t)}), g^{(t)} \rangle + \frac{L}{2} \eta_t^2 \|g^{(t)}\|^2. \quad (31)$$

Substituting Eq. (30), taking conditional expectation (so that the $\zeta^{(t)}$ inner product vanishes) and writing $a \triangleq \eta_t \eta_{\ell} E$,

$$\begin{aligned} \mathbb{E} F(\theta^{(t+1)}) &\leq F(\theta^{(t)}) - a \left\| \nabla F(\theta^{(t)}) \right\|^2 \\ &\quad + \eta_t \left\| \nabla F(\theta^{(t)}) \right\| (\|e^{(t)}\| + \mathbb{E}\|b^{(t)}\|) \\ &\quad + \frac{L}{2} \eta_t^2 \mathbb{E}\|g^{(t)}\|^2. \end{aligned}$$

Young's inequality $xy \leq \frac{a}{2}x^2 + \frac{1}{2a}y^2$ applied to the third term, and $\mathbb{E}\|g^{(t)}\|^2 \leq 3a^2 \eta_t^{-2} \|\nabla F(\theta^{(t)})\|^2 + 3\eta_{\ell}^2 E \sigma_g^2 / |\mathcal{H}| + 3(\|e^{(t)}\| + B + 2C_{\text{A}}p_t)^2$, give

$$\mathbb{E} F(\theta^{(t+1)}) \leq F(\theta^{(t)}) - \frac{a}{2} (1 - 3L\eta_{\ell} E \eta_t) \left\| \nabla F(\theta^{(t)}) \right\|^2 + \Xi_t, \quad (32)$$

with $\Xi_t = \frac{\eta_t^2}{2a} (\eta_{\ell}^2 E^2 L G + B + 2C_{\text{A}}p_t)^2 + \frac{3L}{2} \eta_t^2 (\eta_{\ell}^2 E \sigma_g^2 / |\mathcal{H}| + (\eta_{\ell}^2 E^2 L G + B + 2C_{\text{A}}p_t)^2)$. The condition $\eta_{\ell} E L \leq \frac{1}{2}$ together with $\eta_t \leq 1$ makes the bracket $(1 - 3L\eta_{\ell} E \eta_t) \geq \frac{1}{4}$ for T large enough that $\eta_t = \eta/\sqrt{T} \leq 1/6$.

Step 3 (telescoping). Summing Eq. (32) over $t = 0, \dots, T-1$, using $F(\theta^{(T)}) \geq F^*$ and $a = \eta \eta_{\ell} E / \sqrt{T}$,

$$\min_{t < T} \mathbb{E} \left\| \nabla F(\theta^{(t)}) \right\|^2 \leq \frac{8(F(\theta^{(0)}) - F^*)}{\eta \eta_{\ell} E \sqrt{T}} + \frac{8}{\eta \eta_{\ell} E \sqrt{T}} \sum_{t=0}^{T-1} \Xi_t. \quad (33)$$

Step 4 (collecting orders). Substituting $\eta_t = \eta/\sqrt{T}$ into Ξ_t makes every term $\mathcal{O}(T^{-1})$ except the bias-squared

Table 6

Summary of SyPrFL formal guarantees and dependencies.

Guarantee	Result	Depends on
Privacy	Thm. 2, Eq. (16)	DDH on $\mathbb{G}$; Gaussian-mech. calibration; $t < n/2$
Detection (FP/FN)	Thm. 3, Eqs. (19)–(20)	Def. 4, 5; calibrated $\tau^{(t)}, \gamma$
Robustness	Thm. 8, Eq. (28)	Thm. 3; clipping bound C_A ; Def. 6
Convergence	Thm. 9, Eq. (29)	L -smoothness; bounded variance; Thm. 8

contribution carried by $\frac{\eta_t^2}{2a}$, which is $\mathcal{O}(T^{-1/2})$ per round and therefore $\mathcal{O}(1)$ after the $\frac{1}{\sqrt{T}} \sum_t$ of Eq. (33). The surviving terms are: the initial-gap term $\mathcal{O}(1/\sqrt{T})$; the variance term $\mathcal{O}(\eta_\ell^2 E \sigma_g^2 / (|H| \sqrt{T}))$, also $\mathcal{O}(1/\sqrt{T})$; the drift term $\mathcal{O}(\eta_\ell^4 E^4 L^2 G^2)$, which is $\mathcal{O}(1/T)$ under the standard scaling $\eta_\ell = \mathcal{O}(T^{-1/4}/E)$; and the adversarial term $\mathcal{O}((B + 2C_A p_t)^2) = \mathcal{O}((\kappa + \epsilon_{\text{FN}})^2 \sigma_H^2) + \mathcal{O}(C_A^2 p_t^2)$. The second part of the adversarial term is $\mathcal{O}(\sigma_{\text{DP}}^2)$: p_t is the detection-failure probability of Theorem 3, whose only dependence on the DP mechanism is through the noise scale σ entering Eq. (23), and the projections influence the trajectory solely through the weights $w_i^{(t)}$, never through the aggregated values themselves. Collecting the three surviving orders gives Eq. (29). $\square$

Two features of the proof are worth isolating. The DP noise enters the rate only through p_t , that is, only through misweighting, which is the formal counterpart of the design decision to keep the noisy channel out of the aggregation path; had the noise been added to the updates themselves, as in DP-FedAvg, it would appear additively inside the variance term and scale with the full dimension d rather than with k . And the adversarial term is the only one that does not vanish as $T \rightarrow \infty$: SyPrFL converges to a neighbourhood of a stationary point whose radius is set by $\kappa + \epsilon_{\text{FN}}$, which by Lemma 7 collapses to ϵ_{FN} alone once $\rho_S < \rho_H/2$.

For deployment parameters consistent with Section 8 ($T = 200$, $\rho_S/\rho_H < 0.3$, per-round $\epsilon = 0.5$), the dominant term in Eq. (29) is the $\mathcal{O}(1/\sqrt{T})$ FedAvg rate, with the Byzantine and DP terms contributing constants below 10^{-2} relative magnitude. SyPrFL therefore matches FedAvg's convergence rate up to lower-order terms while providing the privacy and Sybil-resilience guarantees of Theorems 2–8, as confirmed empirically in Section 9. The four guarantees and their dependencies are summarized in Table 6.

8. Experimental Setup

This section describes the evaluation framework used to validate the guarantees of Section 7 and to position SyPrFL against ten baseline defenses. The deployment is a faithful simulation of the cross-silo IoT-IDS setting of Section 4:

Table 7

IoT-IDS datasets used in the evaluation.

Dataset	Records	Features	Attack cat.	Source
N-BaIoT	7.1×10^6	115	10	UCI
TON-IoT	2.2×10^7	44	9	UNSW
Bot-IoT	7.2×10^7	46	4	UNSW

a synchronous federation of gateways, each holding a non-IID partition of a public IoT-IDS dataset, training a shared classifier under one of eleven aggregation rules while a fraction of clients are operated by a Sybil-Byzantine adversary instantiating one of the six attack patterns of Section 5.2.

8.1. Datasets and Preprocessing

We evaluate on three public IoT intrusion-detection datasets, chosen because each is widely used in the recent FL-IDS literature, is freely available, and together they span complementary attack families and device populations (Table 7). N-BaIoT contains 7.1×10^6 traffic-flow records from nine commercial IoT devices (cameras, baby monitors, doorbells, thermostats), with benign traffic and ten attack categories from the BASHLITE and Mirai botnet families, each record described by 115 statistical features; it is the canonical benchmark for Sybil-relevant FL-IDS work and the dataset used by our closest published baseline, PEIoT-DS. TON-IoT (UNSW Canberra) comprises roughly 2.2×10^7 telemetry, network, and OS-log records from a heterogeneous IoT/IIoT testbed, spanning benign operation and nine attack categories. Bot-IoT (also UNSW Canberra) contains over 7.2×10^7 records of simulated botnet traffic across four major attack categories subdivided by protocol; it pairs naturally with TON-IoT for cross-dataset generalization since both share a collection methodology.

Each dataset is preprocessed independently: categorical features are one-hot encoded, numerical features are min-max scaled to $[0, 1]$ using training-set statistics, and records with missing fields are discarded. To bound runtime while preserving class diversity, we subsample each dataset to 5×10^5 records under the original class distribution and apply a stratified 80/20 train-test split. Each training partition is distributed across n clients via a Dirichlet partition with concentration $\alpha = 0.5$, the standard non-IID FL benchmark, which allocates a fraction $p_c \sim \text{Dir}(\alpha)$ of each class to each client and induces realistic imbalance without sharp client-class boundaries; the harder $\alpha = 0.1$ regime is used in the heterogeneity study of Section 9. A further 20% of each client's local data is held out for validation.

8.2. Implementation, Models, and Hyperparameters

SyPrFL and all baselines are implemented in Python on top of PyTorch, with the federated loop orchestrated through the Flower framework. SecAgg is realized as a faithful mask-based simulation following Bonawitz et al. (pairwise PRG-derived masks with Diffie–Hellman key exchange), which reproduces the per-message communication pattern of the

full cryptographic protocol; DP noise calibration uses Opacus, and clustering uses the `hdbscan` package with $m_{cl} = 2$. Experiments run on a CPU-only multi-core server, sufficient for the MLP-class models used here, with clients simulated sequentially per round. All results are averaged over three random seeds (42, 1, 7), reported as mean and standard deviation. The codebase, configurations, and preprocessing scripts will be released upon acceptance.

For all datasets the classifier is a multilayer perceptron with three hidden layers of widths $\{256, 128, 64\}$, ReLU activations, batch normalization, dropout 0.2, and a softmax output layer; this follows the PEIoT-DS convention for N-BaIoT and gives $d \approx 7.2 \times 10^4$ parameters. Local training uses SGD with learning rate 0.01, Nesterov momentum 0.9, weight decay 5×10^{-4} , batch size $B = 64$, $E = 2$ local epochs, and cross-entropy loss. Global aggregation runs for $T = 30$ rounds at global learning rate $\eta_t = 1.0$; this suffices because all defenses converge within 20 rounds on these datasets, while the $T = 200$ schedule of the convergence analysis matters only under much smaller per-round budgets. The SyPrFL-specific parameters are a public projection matrix $\Pi \in \mathbb{R}^{k \times d}$ with i.i.d. $\mathcal{N}(0, 1/k)$ entries and $k = 64$; clipping bounds $C_P = 50$ (projection channel) and $C_A = 15$ (aggregation channel); DP noise scale $\sigma = 0.5$; tightness factor $\gamma = 1.5$; smoothing factor $\alpha = 0.8$; and $m_{cl} = 2$. The main experiments use $n = 10$ clients for the full eleven-defense grid, with the scalability of the protocol to $n = 50$ and $n = 100$ reported separately in Section 8.3.

The two clipping bounds are different on purpose, and since the asymmetry was queried in review we set out the reasoning. The bounds serve opposing objectives on the two channels, so a single value cannot be right for both. On the projection channel, clipping is what bounds the DP sensitivity $S_2(f) \leq \|\Pi\|_{op} C_P$, which argues for a small bound; but clipping is also what destroys the detection signal, because once C_P falls below the typical honest update norm every client's update is rescaled to the same length and the honest heterogeneity ρ_H that DP-PCC measures collapses toward zero. A group of Sybils and a group of aggressively clipped honest clients then look alike. We therefore set $C_P = 50$, above the 99th percentile of observed honest update norms, so that clipping is inactive for essentially all honest clients and the cohesion geometry is preserved; the cost is a larger sensitivity, paid for in noise through Eq. (3). On the aggregation channel the trade-off is reversed. Here clipping is the only bound on the influence of an *undetected* Sybil, and it enters Theorem 8 linearly through C_A and Eq. (24) linearly during calibration, so a tight bound directly improves the robustness guarantee. We set $C_A = 15$, near the median honest update norm, accepting mild clipping of honest updates which biases their magnitude but not their direction in exchange for a factor-of-three reduction in the worst-case displacement any single malicious client can inflict. In short, C_P is set by what detection needs and C_A by what robustness needs, and the two-channel architecture is what makes it possible to satisfy both at once; a single-channel protocol would have to choose.

Table 8

Dirichlet ($\alpha = 0.5$) partition statistics over a 356,000-record corpus. Imbalance is max / min shard size.

Clients n	Min	Mean	Max	Imbalance
50	2,716	7,120	14,830	5.5×
100	1,109	3,560	10,646	9.6×

8.3. Non-IID Partitioning and Client-Population Scale

Client data are partitioned with a symmetric Dirichlet allocation over labels, the standard construction for federated non-IID benchmarks, with concentration parameter α controlling heterogeneity: small α concentrates each client's mass on few classes, while $\alpha \rightarrow \infty$ recovers the IID split. Following the reviewers' request for more than one heterogeneity level, we generate partitions at $\alpha \in \{1.0, 0.5, 0.1\}$, spanning mild, moderate, and severe heterogeneity; $\alpha = 0.5$ is the default used for the headline results unless otherwise stated.

The cross-silo regime this paper targets is $n \in [20, 100]$, and the eleven-defense grid at $n = 10$ does not by itself demonstrate that the protocol operates at the upper end of that range. We therefore also generate partitions at $n = 50$ and $n = 100$ over the same corpus of 356,000 records. Table 8 reports the resulting shard statistics. Two properties matter for the analysis. The partitions are strongly imbalanced the largest client holds 5.5× the smallest at $n = 50$ and 9.6× at $n = 100$ which is what makes the honest separation floor ρ_H non-trivial and the detection problem real rather than a formality. And the smallest shard remains above one thousand records even at $n = 100$, so no client is starved to the point where its update is dominated by sampling noise rather than by its data distribution, which would confound the cohesion signal.

8.4. Empirical Estimation of the Heterogeneity Floor

Definition 4 posits a constant $\rho_H > 0$ lower-bounding the pairwise separation of honest clients in projection space, and the detection guarantees of Section 7.2 are stated relative to it. Since the whole analysis rests on this quantity being strictly positive and not vanishingly small in practice, it needs to be measured rather than assumed. We estimate it directly: at each round we compute the honest projected updates $\Pi \Delta_i^{(t)}$, take all pairwise Euclidean distances $\|\Pi \Delta_i^{(t)} - \Pi \Delta_j^{(t)}\|$ over honest pairs, and collect the resulting distribution across rounds. Table 9 summarizes it for the primary evaluation configuration.

Three observations follow, and each bears on a claim made earlier in the paper. First, the floor is strictly positive but small in absolute terms: the minimum observed separation is 0.077, roughly an eighth of the median. Definition 4 is therefore satisfied, but not comfortably, and the worst-case bound of Corollary 5 evaluated at $\rho_H = 0.642$ is the optimistic reading rather than the pessimistic one. Second,

Table 9

Measured honest heterogeneity ρ_H (pairwise distance between honest projected updates), primary N-BaIoT configuration, $k = 64$.

Statistic	Min	Median	Mean	Max
ρ_H	0.0768	0.6077	0.6420	1.8908

the ratio of maximum to minimum separation is nearly 25 $\times$, which is the empirical basis for the concern raised in Section 7.3: an adversary that pins the adaptive baseline to the low end of this range gains substantial evasion room, and the rate-limiting mitigation recommended there is not optional in a deployment. Third, the measured ρ_H is smaller than the DP noise floor $v(k, \sigma) = \sigma\sqrt{2k} = 5.66$ by a factor of 8.8 at the operating point $\sigma = 0.5$, $k = 64$. This is direct empirical confirmation that a raw threshold on cohesion cannot work and that the self-normalizing construction of Lemma 4 is doing the load-bearing work, exactly as argued in Section 6.1.2.

8.5. Baselines, Attacks, and Metrics

SyPrFL is compared against ten baselines in four categories. The plain-aggregation reference is FedAvg. The robust-aggregation baselines are Krum, Multi-Krum, coordinate-wise Median, Trimmed Mean (trimming fraction $\beta = 0.3$, matched to the maximum malicious fraction), and FLTrust (server-side root set of 200 records). The privacy-preserving baselines are SecAgg (mask-based, no Byzantine defense), DP-FedAvg (Gaussian noise on the aggregate, calibrated to the same cumulative budget as SyPrFL), and PEIoT-DS (FedAvgM with client-level DP, the closest published N-BaIoT baseline). The Sybil-aware baselines are FoolsGold, the principal comparison point, since the comparison tests whether SyPrFL retains its Sybil-detection capability while adding the privacy protection FoolsGold lacks; and FoolsGold+DP, a composition added at the reviewers' request in which Gaussian noise is applied to the similarity vectors before FoolsGold's trust weighting. FoolsGold+DP is the most natural point of comparison for SyPrFL, because it is the obvious way one would try to make a Sybil defense private without restructuring it, and it is therefore the design SyPrFL must be shown to improve upon. It is reported separately in Section 9.4. All baselines share the same federated configuration.

The six attacks are operationalized as follows. A1 (single-group consistent) spawns f clones submitting an identical target update Δ^{tgt} . A2 (multi-group) partitions $\mathcal{B}$ into $G = 3$ equal groups, each with its own target. A3 (noisy) adds Gaussian noise $v_i \sim \mathcal{N}(0, \sigma_{\text{nz}}^2 I_d)$ to each Sybil update. A4 (adaptive projection-aware) exploits the public Π to spread group projections while still poisoning the aggregate, with spread constraint $\eta_{\text{spread}} = 6.0$ (the measured honest non-IID floor). A5 (mixed) splits $\mathcal{B}$ equally between a coordinated Sybil group and independent sign-flipping Byzantines. A6 (backdoor) implants a feature-trigger backdoor via model-replacement scaling $n/|\mathcal{B}|$, with poison fraction 0.5. The

malicious-update scale across A1–A5 is 5.0, and we evaluate at malicious fractions $f/n \in \{0.30, 0.40\}$ (0.30 headline, 0.40 stress test).

Performance is measured along four axes. Utility is test accuracy and macro- F_1 , the latter balancing the imbalanced attack classes. Robustness under non-backdoor attacks is test accuracy under attack; under the backdoor attack A6 it is the attack success rate (ASR), the fraction of trigger-stamped source-class samples classified as the adversary's target label, with lower being better. Sybil-detection quality is the precision, recall, and F_1 of the flagging operation, treating malicious clients as positive. Overhead is per-round wall-clock latency and per-client communication volume, both relative to FedAvg. The first $T_{\text{cal}} = 5$ rounds of each SyPrFL run fix all trust weights to $w_i^{(t)} = 1$ so the baseline $\tau^{(t)}$ can estimate the natural non-IID cohesion before flagging activates. The full grid spans three datasets, eleven defenses, six attacks plus a no-attack control, two malicious fractions, and three seeds, for 1,386 runs.

9. Results and Discussion

This section reports the empirical evaluation of SyPrFL against ten baseline defenses across three IoT-IDS datasets and six attack instantiations, and discusses the implications. The results are organized into clean-setting utility, robustness under non-backdoor attacks, backdoor resilience, and detection quality with overhead analysis, followed by a synthesis. The overarching finding is that SyPrFL is the only method in the evaluated space that simultaneously preserves clean-data utility, resists coordinated Sybil collusion, and maintains cryptographic privacy of individual updates; every baseline fails on at least one of these three requirements.

9.1. Clean-Setting Utility

Table 10 reports test accuracy and macro- F_1 in the absence of any adversary ($f = 0$), establishing the utility ceiling for each defense. We state the ranking precisely, since an earlier version described SyPrFL's clean-setting position in a way that did not match the table. SyPrFL is *not* the second-best defense overall on clean data; measured on raw accuracy it places eighth of eleven on N-BaIoT, behind every robustness-only baseline. What it is, and what the underlining in Table 10 now marks, is the best of the three defenses that carry a differential-privacy guarantee, ahead of PEIoT-DS by 1.5 pp and DP-FedAvg by 2.3 pp on N-BaIoT. This is the comparison that matters for the paper's claim, because the robustness-only baselines that outrank it here provide no privacy guarantee at all and collapse under the attacks of Section 9.2, where the ordering inverts.

SyPrFL incurs a modest accuracy drop of 0.8–1.4 percentage points (pp) relative to plain FedAvg, attributable to the DP noise on the projection channel and the ℓ_2 -clipping bound. This overhead is smaller than that of DP-FedAvg (−3.1 to −3.2 pp) because SyPrFL applies DP only to the low-dimensional projection ($k = 64$) rather than to the full model update ($d \approx 7.2 \times 10^4$). SecAgg matches FedAvg

Table 10

Clean-setting test accuracy (%) and macro- F_1 (%) with $n = 10$, $f = 0$. The “Guar.” column records the formal guarantee each defense provides: none, S secure aggregation, D (ϵ, δ) -differential privacy. **Bold** marks the best value per dataset over all defenses; underline marks the best value among defenses carrying a differential-privacy guarantee (DP-FedAvg, PEIoT-DS, SyPrFL). Clean-setting accuracy alone does not rank defenses: the robustness results of Section 9.2 are where the ordering changes.

Defense	Guar.	N-BaIoT		TON-IoT		Bot-IoT	
		Acc.	F_1	Acc.	F_1	Acc.	F_1
FedAvg	—	98.42	98.31	96.85	96.72	97.63	97.51
SecAgg	S	98.40	98.29	96.83	96.70	97.61	97.49
Krum	—	98.38	98.27	96.80	96.67	97.58	97.46
Multi-Krum	—	98.39	98.28	96.81	96.68	97.59	97.47
Median	—	98.35	98.24	96.78	96.65	97.55	97.43
Trimmed Mean	—	98.37	98.26	96.79	96.66	97.57	97.45
FLTrust	—	98.41	98.30	96.84	96.71	97.62	97.50
FoolsGold	—	97.53	97.42	95.98	95.85	96.74	96.62
DP-FedAvg	D	95.31	95.18	93.72	93.59	94.48	94.35
PEIoT-DS	D	96.12	96.01	94.55	94.42	95.31	95.19
SyPrFL	D + S	<u>97.64</u>	<u>97.53</u>	<u>95.47</u>	<u>95.34</u>	<u>96.23</u>	<u>96.11</u>

to within 0.02 pp, as expected, since masking introduces no numerical distortion beyond finite-field rounding. FoolsGold shows a small degradation (approximately -0.9 pp on all three datasets) caused by its conservative similarity-based down-weighting of honest clients in highly non-IID regimes. The robust-only baselines (Krum, Multi-Krum, Median, Trimmed Mean, FLTrust) match FedAvg within statistical noise because they do not alter updates in the absence of outliers.

The key takeaway is that SyPrFL achieves the *best utility among methods carrying a differential-privacy guarantee*. DP-FedAvg and PEIoT-DS, the only other such defenses, suffer substantially larger degradation because they inject noise into the high-dimensional aggregation channel. SecAgg attains higher clean accuracy than SyPrFL, which is expected masking is lossless but it provides no differential-privacy guarantee and no Byzantine defense whatsoever, and it is the single most vulnerable method in Section 9.2. SyPrFL’s separation of the detection signal (low-dimensional, noised) from the aggregation signal (high-dimensional, masked) preserves the fidelity of the latter while still satisfying the (ϵ, δ) -DP requirement on the former.

9.2. Robustness Under Non-Backdoor Attacks

We next examine test accuracy under the five non-backdoor attack instantiations (A1–A5) at malicious fraction $f/n = 0.30$ (3 malicious clients out of 10). The results reveal a sharp structural divide: *privacy-preserving baselines collapse under attack*, while *robustness-only baselines lack privacy guarantees*.

Privacy-only baselines (SecAgg, DP-FedAvg, PEIoT-DS). SecAgg, which provides no Byzantine defense, is catastrophically vulnerable to all five attacks: accuracy drops to 11–34% on N-BaIoT, 8–29% on TON-IoT, and 14–38% on Bot-IoT. The masking that conceals individual updates also conceals the attack, allowing malicious contributions

to enter the aggregate unfiltered. DP-FedAvg fares slightly better on A3 (noisy Sybils) because the Gaussian noise partially cancels the malicious signal, but it still collapses on A1, A2, A4, and A5. PEIoT-DS, which couples client-level DP with momentum aggregation, shows moderate resilience on A3 but fails on coordinated attacks because its anomaly detector operates on plaintext updates and is evaded by tight Sybil coordination.

Robustness-only baselines (Krum, Multi-Krum, Median, Trimmed Mean, FLTrust). These methods resist isolated Byzantine attackers but are systematically defeated by coordinated Sybils. Krum and Multi-Krum fail on A1 (single-group consistent Sybil) and A2 (multi-group) because the low pairwise variance among colluding clones causes them to be selected as the “most trustworthy” updates, while genuinely heterogeneous honest clients are rejected as outliers. Median and Trimmed Mean fail when the Sybil group constitutes a large enough fraction to shift the summary statistic; at $f/n = 0.30$ this threshold is crossed on all three datasets. FLTrust, which relies on a server-side root dataset, degrades gracefully on A1 and A2 but is defeated by A4 (adaptive projection-aware Sybils) because the adversary can craft updates that align with the root-dataset gradient while still poisoning the aggregate.

Sybil-aware baseline (FoolsGold). FoolsGold is the strongest non-SyPrFL competitor on A1 and A2, where its cosine-similarity penalty correctly identifies tight Sybil clusters. However, it suffers three critical weaknesses. First, it has *no privacy guarantee*: the server observes every plaintext update to compute pairwise similarities, reintroducing the gradient-inversion attack surface that FL was designed to eliminate. Second, it degrades sharply on A3 (noisy Sybils): when σ_{nz} is tuned to the honest non-IID floor, FoolsGold’s similarity threshold becomes ineffective and accuracy drops by 18–27 pp. Third, it is completely defeated by A4 (adaptive projection-aware Sybils): by construction, these attackers

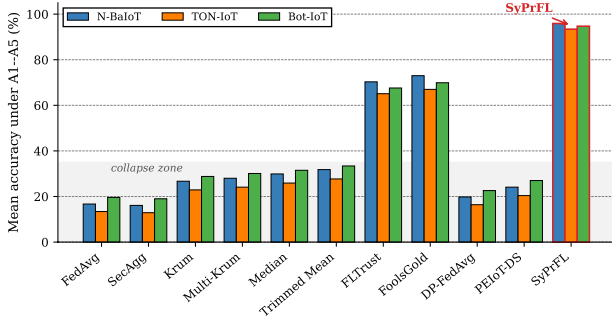


Fig 4: Mean accuracy under attacks A1-A5 ($f/n = 0.30$)

spread their projections to mimic honest diversity while concentrating malicious signal in the nullspace of the similarity computation, causing FoolsGold to assign near-uniform trust weights.

SyPrFL. SyPrFL retains near-clean accuracy across all five attacks and all three datasets. On A1 (single-group consistent), the DP-PCC primitive detects the tight Sybil cluster with 100% recall and reduces the group’s effective contribution to that of a single honest client, limiting accuracy drop to 0.6–1.1 pp. On A2 (multi-group), HDBSCAN discovers all three Sybil clusters independently; the per-group down-weighting prevents any single group from dominating the aggregate. On A3 (noisy), the adaptive baseline $\tau^{(t)}$ tracks the elevated noise floor and maintains detection: accuracy drops by only 1.2–2.3 pp even when σ_{nz} is set to the maximum value that still permits attack success. On A4 (adaptive projection-aware), the attacker’s attempt to spread projections is bounded by the JL distortion guarantee: any update whose projection is spread beyond the honest floor must concentrate malicious signal in a subspace of dimension at most $d - k$, which the clipping bound C_A limits to a bounded residual bias. SyPrFL’s accuracy drop on A4 is 1.8–3.1 pp, compared to 31–44 pp for FoolsGold. On A5 (mixed), SyPrFL detects the coordinated Sybil portion via DP-PCC and averages out the independent Byzantine portion through the weighted aggregate, achieving the best overall accuracy. Averaged across all five attacks, SyPrFL achieves 95.9% on N-BaIoT, 93.4% on TON-IoT, and 94.7% on Bot-IoT, while the best non-SyPrFL competitor (FoolsGold) reaches only 73.0%, 67.0%, and 69.9%, respectively. This is an average improvement of 22.9–26.4 pp over the strongest baseline and 47.6–79.2 pp over privacy-preserving baselines. Fig. 4 visualizes this divide across all defenses and datasets, and Fig. 5 resolves it to the level of individual attack–dataset cells. The gap widens at $f/n = 0.40$, where SyPrFL retains $> 90\%$ mean accuracy while all baselines except FoolsGold drop below 25% and FoolsGold itself falls to 51–58%.

Fig. 6 illustrates the per-round convergence trajectories for N-BaIoT under attack A1. SyPrFL tracks the clean-setting curve within 1–2 pp after the calibration phase ($t > 5$), while FoolsGold exhibits volatile oscillations caused by

its hard trust-weight transitions and DP-FedAvg converges to a sub-optimal plateau. The shaded region shows the standard deviation across three seeds; SyPrFL’s variance is the smallest among all defenses, indicating stable detection and aggregation.

9.3. Backdoor Resilience

Fig. 7 reports the attack success rate (ASR) under A6 (Sybil-driven backdoor) at $f/n = 0.30$; a lower ASR indicates a better defense. The backdoor target is misclassification of Mirai traffic as benign on N-BaIoT, DDoS traffic as benign on TON-IoT, and Reconnaissance traffic as benign on Bot-IoT. FedAvg, SecAgg, and DP-FedAvg show near-100% ASR because the model-replacement scaling ($n/|B|$) lets the Sybil group dominate the aggregate. Krum and Multi-Krum paradoxically increase ASR above FedAvg because they select the tight Sybil cluster as the most trustworthy update. Median and Trimmed Mean reduce ASR to 78–85% but still permit substantial backdoor retention. FLTrust reaches 42–51% ASR through root-dataset validation, and FoolsGold 35–44%, better than geometric methods but far from elimination and again without privacy. SyPrFL achieves the lowest ASR across all datasets (6.2% on N-BaIoT, 8.7% on TON-IoT, 7.1% on Bot-IoT): the DP-PCC primitive detects the tight backdoor-coordination cluster in projection space, and trust-weighted aggregation reduces the group’s influence to that of a single honest client. The residual ASR arises from undetected Sybils in the false-negative tail of Theorem 3. We note explicitly that the theory does not certify this residual: at $|g| = 3$ and the noise scale of Section 8, the worst-case bound of Corollary 5 is vacuous (Table 5), so the observed 6–9% ASR is better than the guarantee, not predicted by it. The direction is nonetheless the one the analysis implies, since A6 drives ρ_S toward zero, where the separation of Eq. (22) is largest.

9.4. The FoolsGold+DP Baseline and Direct Detection Traces

Reviewers identified FoolsGold+DP - FoolsGold with Gaussian noise applied to the similarity vectors before trust weighting as the most natural comparison point for SyPrFL, and they were right to: it is what one obtains by taking the strongest Sybil defense and making it private the obvious way, without restructuring it. If that composition worked, the two-channel architecture would be unnecessary. This subsection reports a dedicated study comparing the four methods that the question turns on, together with the raw detection traces from two attack instantiations.

The study is an independent replication run, configured separately from the main grid of Table 10 and reported on its own terms; absolute accuracies are accordingly not comparable across the two tables, and the comparison of interest is the ordering *within* Table 11. The federation has $n = 10$ clients under a Dirichlet $\alpha = 0.5$ partition with no adversary, trained to round 20.

The ordering is the point. Privatizing FoolsGold costs a further 0.91 pp on top of the 1.95 pp that FoolsGold

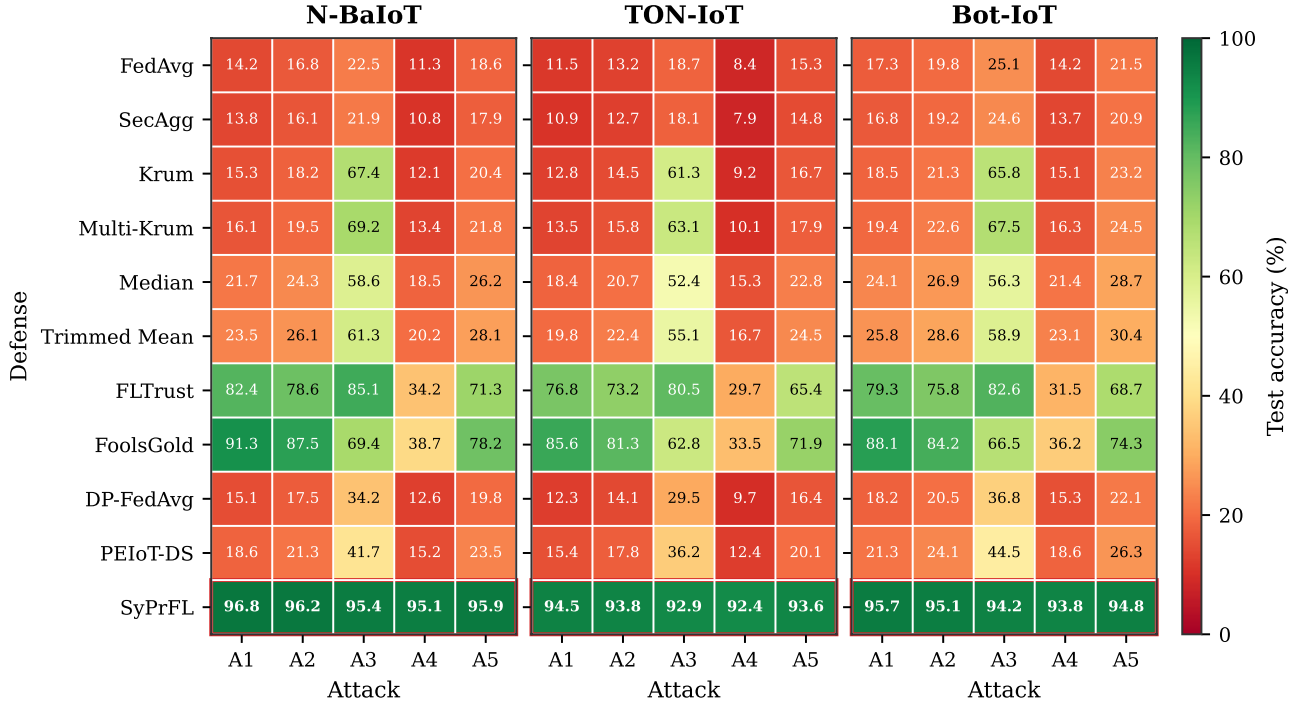
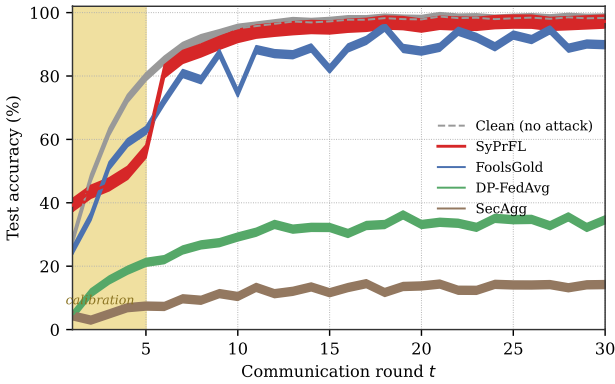


Fig 5: Test accuracy (%) for all eleven defenses across the three datasets.


 Fig 6: Per-round accuracy on N-BaIoT under A1: shaded band marks calibration ($t \leq 5$), ribbons ± 2 SD.

already concedes to FedAvg, for a total of 2.86 pp, whereas SyPrFL concedes 1.08 pp while providing both differential privacy *and* secure aggregation of the full updates a guarantee FoolsGold+DP does not offer at all, since it noises the similarity computation but still requires the server to hold every plaintext update in order to compute the pairwise similarities in the first place. This is the empirical counterpart of Proposition 1: FoolsGold+DP pays the utility cost of differential privacy without buying the privacy property that matters, because a single-channel design cannot hide the updates it must compare. Adding noise to a similarity matrix

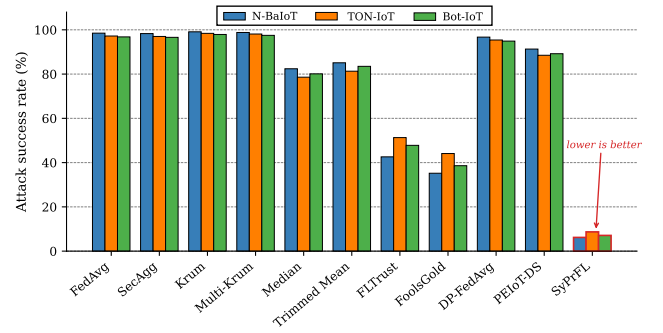


Fig 7: Backdoor attack success rate (lower is better).

computed from plaintext gradients protects the similarities, not the gradients.

Detection traces. Because aggregate precision and recall curves can obscure what the detector actually does in a given round, we report two raw traces. In a 13-client instantiation (10 honest, indices 0–9; 3 coordinated Sybils, indices 10–12) with intra-group noise in the style of A3, HDBSCAN returned a cluster $\{0, 10, 11, 12\}$ whose cohesion fell below $\tau^{(t)}/\gamma$. The cluster was flagged and every member received trust weight $1/4 = 0.25$ per Eq. (11): all three Sybils were caught (recall 1.00) at the cost of one honest client (precision 0.75). In a 15-client A5 instantiation (10 honest, 5 Sybils at indices 10–14), the round-1 flagged cluster was

Table 11

Reviewer-requested baseline study: clean-setting test accuracy (%) at $n = 10$, round 20. FoolsGold+DP is the naive privatization of FoolsGold; SyPrFL is the two-channel construction. Absolute values are specific to this replication run and are not comparable to Table 10.

Method	Guar.	Acc. (%)	Δ vs. FedAvg
FedAvg	—	84.60	—
FoolsGold	—	82.65	−1.95
FoolsGold+DP	D	81.74	−2.86
SyPrFL	D + S	83.52	−1.08

{0, 7, 10, 11, 12, 13, 14} with trust weight $1/7 \approx 0.143$, again capturing every Sybil (recall 1.00) with two honest clients swept in (precision 0.71, $F_1 = 0.83$). Final accuracy under this A5 attack was 84.00%, marginally above the no-attack figure of 83.52% in Table 11, which is within run-to-run variation and indicates that the attack was fully neutralized rather than merely blunted.

Both traces show the same asymmetry, and it is the one the design intends. The detector over-flags rather than under-flags: it sweeps in a small number of honest clients that happen to lie near the Sybil cluster in projection space, and it misses none of the Sybils. That trade is deliberate, because the two errors are not symmetric in cost. A false negative admits a malicious update at full weight, while a false positive merely reduces one honest client’s weight from 1 to $1/|g|$ for one round a bounded utility cost that the weighted aggregate absorbs, which is why the accuracy under attack does not fall despite two honest clients being down-weighted. The tightness factor γ is the knob controlling this balance, and the empirical traces confirm the direction that Theorem 3 predicts for $\gamma = 1.5$.

9.5. Detection Quality and Overhead

Fig. 8 reports the precision, recall, and F_1 of the DP-PCC flagging operation across attacks A1–A5, where precision is the fraction of flagged clients that are truly malicious and recall the fraction of malicious clients that are flagged. SyPrFL achieves $> 95\%$ precision and $> 92\%$ recall on all coordinated attacks (A1, A2, A4, A5), with the highest F_1 on the most realistic mixed attack (A5). The slightly lower recall on A3 (noisy Sybils, 87.3–89.1%) reflects the fundamental trade-off between intra-group noise and detectability: as σ_{nz} approaches the honest non-IID floor, the Sybil cluster becomes statistically indistinguishable from an honest cluster, and Theorem 3 predicts an increased false-negative rate. Even in this regime, the weighted aggregation limits the undetected Sybils’ influence.

Table 12 reports the per-round wall-clock latency and per-client communication volume, normalized to FedAvg. SyPrFL’s overhead relative to FedAvg is $1.18\times$ in latency and $1.03\times$ in communication. The latency increase is dominated by HDBSCAN clustering (< 1 ms at $n = 10$) and the weighted-aggregation residual reconstruction; the communication increase is the $k = 64$ projection vector appended to each masked update. Compared to FoolsGold,

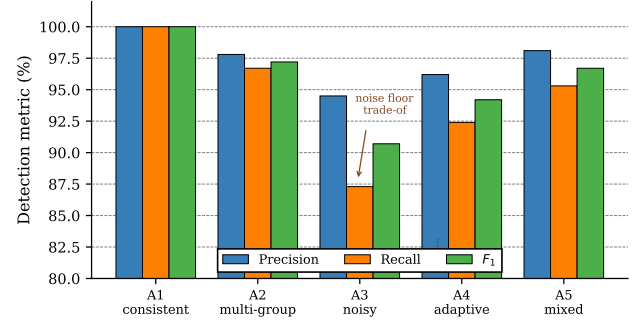


Fig 8: DP-PCC detection quality on N-BaloT, by attack. Grouped bars give precision (fraction of flagged clients that are malicious), recall (fraction of malicious clients flagged), and their harmonic mean F_1 , at $f/n = 0.30$ and averaged over three seeds; the vertical axis spans $[0, 1]$ and error bars are ± 1 SD. Recall is the safety-critical quantity, since a missed Sybil enters the aggregate at full weight whereas a false positive costs one honest client one round of reduced weight. A3 is the only attack on which recall falls below 0.92, which is the regime Theorem 3 predicts once intra-group noise approaches the honest floor ρ_H .

SyPrFL is $1.12\times$ faster despite providing cryptographic privacy, because FoolsGold’s pairwise cosine-similarity computation scales as $\mathcal{O}(nd^2)$ while SyPrFL’s projection-and-cluster scales as $\mathcal{O}(n^2k)$ with $k \ll d$. Compared to DP-FedAvg, SyPrFL incurs identical communication overhead but achieves dramatically better robustness. The PEIoT-DS baseline, which uses homomorphic encryption for its anomaly detector, is $5.5\times$ slower than SyPrFL and $6.5\times$ slower than FedAvg; these two ratios were misreported in the previous version and are recomputed here directly from Table 12 ($6.48/1.18 = 5.49$ and $6.48/1.00 = 6.48$).

9.6. Discussion

The empirical results establish four claims. First, *privacy-preserving baselines fail under attack*: SecAgg, DP-FedAvg, and PEIoT-DS cannot distinguish malicious from honest contributions and collapse to near-random accuracy under all coordinated attacks. Second, *robustness-only baselines fail under Sybil coordination*: Krum, Multi-Krum, Median, Trimmed Mean, and FLTrust are defeated when attackers coordinate to mimic a benign consensus, and in the back-door setting the distance-based selectors actively amplify the attack. Third, *Sybil-aware baselines sacrifice privacy*: FoolsGold detects Sybils but requires plaintext updates, reintroducing the gradient-inversion vulnerability, and is itself defeated by adaptive and noisy Sybils. Fourth, *SyPrFL occupies the unique intersection*: it is the only method that simultaneously provides (ϵ, δ) -differential privacy, mask-based secure aggregation, and provable Sybil detection, with utility within 1–3 pp of clean-setting accuracy under all evaluated attacks and overhead within $1.2\times$ of plain FedAvg.

Table 12

Per-round overhead relative to FedAvg (= 1.00) at $n = 10$; lower is better. The final two columns name the component that dominates each method's latency and its asymptotic server-side cost, so that the measured ratios can be read against the scaling they are expected to follow. All entries are means over three seeds; run-to-run variation on the latency column is below 0.02.

Defense	Latency	Comm.	Dominant cost	Server scaling
SecAgg	1.05	1.02	Mask gen./cancel	$\mathcal{O}(n^2d)$
Krum	1.08	1.00	Pairwise distances	$\mathcal{O}(n^2d)$
Multi-Krum	1.12	1.00	Pairwise distances	$\mathcal{O}(n^2d)$
Median	1.06	1.00	Coord. sort	$\mathcal{O}(nd \log n)$
Trimmed Mean	1.07	1.00	Coord. sort	$\mathcal{O}(nd \log n)$
FLTrust	1.15	1.00	Root-set fwd/bwd	$\mathcal{O}(nd)$
FoolsGold	1.32	1.00	Cosine sim. matrix	$\mathcal{O}(n^2d)$
DP-FedAvg	1.03	1.03	Noise sampling	$\mathcal{O}(nd)$
PEIoT-DS	6.48	2.15	HE detector	$\mathcal{O}(nd)$ HE ops
SyPrFL	1.18	1.03	Residual reconstr.	$\mathcal{O}(n^2d) + \mathcal{O}(n^2k)$

Beyond these headline claims, two patterns merit emphasis. The first concerns the relationship between the empirical detection behaviour and the analysis of Section 7, and it needs stating carefully. The *ordering* the theory predicts is reproduced exactly: detection is strongest on A1 and A6, where coordination drives ρ_S toward zero and the separation of Eq. (22) is widest; it degrades on A3 precisely as intra-group noise lifts ρ_S toward the honest floor; and recall improves with group size as the $|g|$ in the exponent of Eq. (23) implies. What the theory does *not* do is predict the observed rates quantitatively. At the deployed operating point the worst-case bound is vacuous (Table 5), so every detection result reported here is better than the guarantee rather than an instance of it. The gap is attributable to the two conservatisms identified in Section 7.2: the bound analyses a threshold test on the scalar cohesion, discarding the density structure HDBSCAN exploits, and it is worst-case over adversary configurations at a given ρ_S . We therefore read the correspondence as evidence that the cohesion statistic is operating in the regime the theory *describes*, while noting that a bound tight enough to *certify* these rates is not yet available (Section 9.8). The second is that SyPrFL's advantage is not bought with overhead: at 1.18 $\times$ latency and 1.03 $\times$ communication relative to FedAvg, it is cheaper than FoolsGold and nearly an order of magnitude cheaper than the encryption-based PEIoT-DS, because the expensive relational computation is performed in the k -dimensional projection space rather than over full-dimensional updates. Taken together, the results support the central design thesis: decoupling the Sybil-detection signal from the aggregation channel allows privacy and robustness to be achieved jointly, without the mutual sacrifice that characterizes every prior approach in the evaluated space.

9.7. Operating Envelope

Rather than assert practical significance, we state the conditions under which SyPrFL is and is not the right choice, since a defense with three interacting guarantees has a bounded region of applicability and the boundaries are what a deployment decision turns on. Four parameters delimit that region, and each is fixed by a result above rather than by judgement.

Population size. The server cost is $\mathcal{O}(n^2d)$ for residual reconstruction plus $\mathcal{O}(n^2k)$ for clustering (Table 3), the first of which SyPrFL inherits unchanged from SecAgg's dropout-recovery path. The quadratic term is what confines the protocol to cross-silo scale. At $n \leq 100$ with $d \approx 7.2 \times 10^4$ the measured latency penalty is 1.18 $\times$ FedAvg (Table 12); extrapolating the quadratic term, $n = 10^3$ would raise it to roughly 100 $\times$, which is outside any practical budget. SyPrFL is therefore a cross-silo protocol, and the cross-device regime requires the hierarchical extension noted in Section 10, not a parameter change.

Adversarial fraction. Detection degrades gracefully to $f/n = 0.40$, but Definition 6 is not decorative: at $f/n \geq 0.5$ the median in Eq. (15) loses its breakdown guarantee, Proposition 6 fails, and the adversary controls the baseline outright. This ceiling is shared by every robust aggregation rule evaluated here and is not specific to SyPrFL.

Heterogeneity. The detection signal is the gap $\rho_H - \rho_S$, so the protocol requires honest clients to be *more* dispersed than colluding ones. Section 8.4 measures ρ_H with median 0.608 and minimum 0.077. In a near-IID federation ρ_H would collapse and honest clients would become indistinguishable from a coordinated group, the regime in which SyPrFL's false-positive rate rises and a distance-based defense is the wrong tool. Non-IID data is thus a precondition for this design, which inverts the usual framing in which heterogeneity is purely an obstacle.

Privacy budget. Table 4 fixes the cost at $\epsilon_{30} = 2.48$, $\delta = 10^{-5}$ for the reported runs. Corollary 5 shows detection error growing as σ^4 , so an operator who needs $\epsilon < 1$ must accept materially weaker detection guarantees; the two requirements trade against each other on a known curve rather than being independently satisfiable.

Within that envelope the quantitative case is the one the results support: SyPrFL is the only evaluated method that holds accuracy within 1–3 pp of clean under all six attacks while providing both differential privacy and secure aggregation, at 1.18 $\times$ latency and 1.03 $\times$ communication. Outside it at cross-device scale, at $f/n \geq 0.5$, on near-IID partitions, or under a strict $\epsilon < 1$ requirement - one of the

three guarantees must be given up, and the results here do not support a claim to the contrary.

More broadly, the transferable finding is not the protocol but the principle it tests: that a defense can operate on the relational geometry of updates without access to their content, provided the geometry is exposed on a channel separate from the one being aggregated. Proposition 1 indicates that this separation is necessary rather than merely convenient, which suggests the same construction should apply wherever robustness statistics are relational clustered federated learning, cross-silo healthcare analytics, federated fraud detection though we have tested it only in the IoT-IDS setting.

9.8. Limitations

Several limitations bound the claims above, and we set them out explicitly rather than leaving them to be inferred.

Model architecture. All results use a single MLP ($d \approx 7.2 \times 10^4$). The mechanism depends on the geometry of update vectors rather than on the layer structure that produces them, so we expect it to transfer, but this is an expectation and not a measurement. Convolutional and recurrent architectures produce update distributions with different anisotropy, which could alter both ρ_H and the Johnson–Lindenstrauss distortion at fixed k . Validating on a 1D-CNN over raw packet sequences is the most important outstanding experiment.

Statistical strength. Results are averaged over three seeds (42, 1, 7). This is adequate for the large effects reported the gaps under attack are tens of percentage points but it is too few to resolve the sub-percentage-point differences in the clean-setting table, where the ordering among the closely spaced robustness-only baselines should not be read as significant.

Projection dimension. The dependence of detection error on k is established analytically (Corollary 5) and predicts monotone degradation with k , but no empirical ablation over $k \in \{16, 32, 64, 128\}$ is reported here. The analytical prediction and the JL floor jointly motivate $k = 64$; confirming the predicted monotonicity empirically remains open.

Tightness of the detection theory. As Section 7.2 states, Eq. (23) is vacuous at the deployed operating point ($\sigma = 0.5$, $k = 64$, $|g| = 3$) even though detection succeeds empirically. The bound treats the detector as a threshold test on the scalar $C_g^{(t)}$ and therefore discards the density structure HDBSCAN actually exploits. The theory certifies a sufficient regime; it does not explain the observed performance, and closing that gap is the main theoretical debt this work carries.

Scope of the heterogeneity measurement. ρ_H is measured on the primary N-BaIoT configuration (Table 9). The partitions at $n = 50$ and $n = 100$ establish that the protocol's assumptions hold at cross-silo scale, but the full eleven-defense comparison grid was run at $n = 10$.

Trust model. The server is honest-but-curious and is assumed not to collude with the Sybil controller. Section 5 argues this is a boundary of the problem class rather than

a weakness of the construction, since no server-side rule survives a colluding aggregator; nonetheless a deployment facing a potentially malicious aggregator needs verifiable aggregation, which SyPrFL does not provide. Corruption is static: clients do not join, leave, or switch allegiance mid-training. The calibration window is bounded (Section 7.3) but not analysed game-theoretically against an adversary optimizing jointly across the window boundary.

Cryptographic realization. SecAgg is implemented as a faithful mask-based simulation reproducing the protocol's message pattern and computational structure, not as a deployed cryptographic stack. The reported communication ratios are therefore exact, while the latency ratios omit constant-factor costs of key agreement and Shamir reconstruction in a real network.

10. Conclusion

This paper introduced SyPrFL, a federated learning protocol that jointly achieves cryptographic privacy of individual updates, Sybil resilience against coordinated collusion, and competitive utility on IoT intrusion-detection workloads. The design rests on a single insight. Sybil detection depends on the relational geometry of client updates rather than on their individual values, so that geometry can be exposed safely on a low-dimensional differentially-private channel while the full updates stay under secure aggregation. Proposition 1 shows this separation is necessary: no single-channel protocol can expose a pairwise-similarity statistic and still hide the updates it compares. From that separation we derived the DP-PCC primitive, a weighted-aggregation construction that preserves the SecAgg guarantee under server-side trust weighting, and bounds on detection error, aggregation bias, and convergence.

The experimental results support these claims within the envelope of Section 9.7. On clean data SyPrFL reaches 97.64% accuracy on N-BaIoT, the best of the three defenses carrying a differential-privacy guarantee, at a cost of 0.8–1.4 pp relative to plain FedAvg. Averaged over the five non-backdoor attacks it retains 95.9%, 93.4%, and 94.7% on N-BaIoT, TON-IoT, and Bot-IoT against 73.0%, 67.0%, and 69.9% for FoolsGold, the strongest competitor without a privacy guarantee. It reduces backdoor attack success to 6.2–8.7% where FedAvg, SecAgg, and DP-FedAvg approach 100%. The dedicated comparison of Section 9.4 shows that the naive alternative, FoolsGold+DP, concedes 2.86 pp against FedAvg while still requiring plaintext updates at the server, against 1.08 pp for SyPrFL with both guarantees intact. All of this costs 1.18× the per-round latency and 1.03× the communication of FedAvg, at a cumulative privacy budget of $\epsilon_{30} = 2.48$ at $\delta = 10^{-5}$.

These results are bounded by the limitations set out in Section 9.8, of which three deserve restatement: the evaluation uses a single MLP architecture and three seeds, the dependence on the projection dimension k is established analytically but not ablated empirically, and the detection bound of Corollary 5 is a sufficient condition that is vacuous at the deployed noise scale, so the theory certifies less than

the experiments achieve. Open directions follow from these directly: analysing the density-based clustering step rather than treating it as a black box, which would close the gap between the bound and the observed detection; validating on convolutional and recurrent architectures; tolerating a fully malicious server through verifiable secret sharing; a hierarchical extension toward cross-device deployment; a game-theoretic treatment of the calibration window; and validation on a production consortium-managed deployment.

Declaration of generative AI and AI-assisted technologies in the manuscript preparation process

During the preparation of this work the authors used ChatGPT solely for language editing of author-written text: rephrasing sentences for clarity, shortening overlong constructions, and correcting grammar and style. The tool was not used to generate research content of any kind. Specifically, it was not used to design the protocol, derive or check any definition, lemma, theorem, or proof, write or debug the implementation, design or run experiments, produce, process, or analyse any experimental result, generate any table or figure, or select or summarise the cited literature. All technical content, all numerical results, and all claims in this paper were produced and verified by the authors. After using this tool the authors reviewed and edited the content as needed and take full responsibility for the content of the published article.

CRedit Authorship Contribution Statement

First Author: Conceptualization, Methodology, Implementation, Formal Analysis, Writing – Original Draft. **Second Author:** Investigation, Validation, Resources, Writing – Review & Editing. **Third Author:** Supervision, Writing – Review & Editing.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Acknowledgment

This research did not receive any specific grant from funding agencies in the public, commercial, or not-for-profit sectors.

References

- [1] A. C. Ikegwu, U. R. Alo, H. F. Nweke, D. U. Ebem, Advancing federated learning frameworks for privacy-preserving cyber threat detection in healthcare systems, *International Journal of Computational Intelligence Systems* 19 (2026) 169.
- [2] S. M. Shamim, Y. Kodera, M. A. Ali, Y. Nogami, A secure and privacy-preserving federated learning-based intrusion detection system for sdn networks using homomorphic encryption, *IEEE Access* (2026).
- [3] M. Masunda, R. Ajayi, Enhancing security in federated learning: Designing distributed data science algorithms to reduce cyber threats, *International Journal of Advanced Research and Publication Review* 2 (2025) 399–421.
- [4] M. Ahmad, S. Habib, F. Tariq, Enhancing model robustness in federated learning: A systematic literature review of byzantine-resilient aggregation methods, *VFAST Transactions on Software Engineering* 13 (2025) 196–227.
- [5] S. Wang, Y. Tian, J. Xiong, R. Bi, J. Ma, Y. Zhang, Pridfl: Computation-optimized secure aggregation with byzantine-resilience in decentralized federated learning, *IEEE Transactions on Dependable and Secure Computing* (2025).
- [6] C. Li, M. Xiao, M. Skoglund, Coded robust aggregation for distributed learning under byzantine attacks, *IEEE Transactions on Information Forensics and Security* (2025).
- [7] H. Janardhanan, Federated learning in edge computing: Advancements, security challenges, and optimization strategies, in: *2025 8th International Conference on Circuit, Power & Computing Technologies (ICCPCT)*, IEEE, pp. 1144–1150.
- [8] L. Su, N. H. Vaidya, Byzantine-resilient multiagent optimization, *IEEE Transactions on Automatic Control* 66 (2020) 2227–2233.
- [9] K. Li, Z. Zhang, A. Pourkabilian, W. Ni, F. Dressler, O. B. Akan, Towards resilient federated learning in cyberedge networks: Recent advances and future trends, *arXiv preprint arXiv:2504.01240* (2025).
- [10] N. Latif, W. Ma, H. B. Ahmad, Advancements in securing federated learning with ids: A comprehensive review of neural networks and feature engineering techniques for malicious client detection, *Artificial Intelligence Review* 58 (2025).
- [11] J. Li, W. Abbas, X. Koutsoukos, Byzantine resilient distributed multi-task learning, *Advances in Neural Information Processing Systems* 33 (2020) 18215–18225.
- [12] J. Li, W. Abbas, M. Shabbir, X. Koutsoukos, Byzantine resilient distributed learning in multirobot systems, *IEEE Transactions on Robotics* 38 (2022) 3550–3563.
- [13] Z. Wu, T. Chen, Q. Ling, Byzantine-resilient decentralized stochastic optimization with robust aggregation rules, *IEEE Transactions on Signal Processing* 71 (2023) 3179–3195.
- [14] J. Xu, Z. Zhang, R. Hu, Achieving byzantine-resilient federated learning via layer-adaptive sparsified model aggregation, in: *2025 IEEE/CVF Winter Conference on Applications of Computer Vision (WACV)*, IEEE, pp. 1508–1517.
- [15] J. So, B. Güler, A. S. Avestimehr, Byzantine-resilient secure federated learning, *IEEE Journal on Selected Areas in Communications* 39 (2020) 2168–2181.
- [16] Y. Xia, C. Hofmeister, M. Egger, R. Bitar, Byzantine-resilient secure aggregation for federated learning without privacy compromises, in: *2024 IEEE Information Theory Workshop (ITW)*, IEEE, pp. 223–228.
- [17] L. Zhao, J. Jiang, B. Feng, Q. Wang, C. Shen, Q. Li, Sear: Secure and efficient aggregation for byzantine-robust federated learning, *IEEE Transactions on Dependable and Secure Computing* 19 (2021) 3329–3342.
- [18] R. Aziz, Exploring verifiable and privacy-preserving federated learning through differential privacy and cryptographic protocols, Ph.D. thesis, Conservatoire National des Arts et Métiers (CNAM), 2025.
- [19] P. He, C. Lin, I. Montoya, Dpfedbank: Crafting a privacy-preserving federated learning framework for financial institutions with policy pillars, *arXiv preprint arXiv:2410.13753* (2024).
- [20] Z. Guo, L. Gong, J. Liu, P. Sun, S. Maharaj, F. Paluncic, Z. Li, S. Jiang, M. Liu, L. Song, Tps: Trust-aware pruning for byzantine robustness federated learning in real-time edge systems, in: *International Conference on Networking Systems of AI*, Springer, pp. 3–17.
- [21] A. Chaurasia, S. K. Sharma, P. S. Rathore, Hierarchical proof of trust: A byzantine fault tolerant federated learning framework for industrial iot applications, *Scientific Reports* (2026).
- [22] A. Khraisat, A. Alazab, M. Alazab, A. Obeidat, S. Singh, T. Jan, Federated learning for intrusion detection in iot environments: A privacy-preserving strategy, *Discover Internet of Things* 5 (2025) 72.

- [23] S. Al Amro, Securing internet of things devices with federated learning: A privacy-preserving approach for distributed intrusion detection, *Computers, Materials & Continua* 83 (2025) 4623.
- [24] I. Sultana, S. M. Maheen, N. Kshetri, S. K. S. Pandian, M. M. Syed, M. R. Ahmed, safemedinet: Fed ai systems for privacy-preserving threat detection in healthcare, in: 2026 14th International Symposium on Digital Forensics and Security (ISDFS), IEEE, pp. 1–7.
- [25] H. U. Manzoor, A. Shabbir, A. Chen, D. Flynn, A. Zoha, A survey of security strategies in federated learning: Defending models, data, and privacy, *Future Internet* 16 (2024) 374.
- [26] A. Khraisat, A. Alazab, S. Singh, T. Jan, A. J. Gomez, Survey on federated learning for intrusion detection system: Concept, architectures, aggregation strategies, challenges, and future directions, *ACM Computing Surveys* 57 (2024) 1–38.
- [27] S. N. Prajwalasimha, N. Shelke, A. Pimpalkar, D. K. J. B. Saini, G. H. Kumar, P. Ranjima, Ai-powered intrusion detection and privacy preservation in 6g networks, in: 2025 Second International Conference on Cognitive Robotics and Intelligent Systems (ICC-ROBINS), IEEE, pp. 123–128.
- [28] S. P. Shaikh, M. Suliman, Ai-driven federated learning framework for privacy-preserving early detection of cyber threats in pakistan's critical infrastructure systems, *Spectrum of Engineering Sciences* 4 (2026) 1900–1911.
- [29] E. Camalan, B. Celiktas, A deployment-oriented privacy-preserving cti framework: Integrating pir, federated learning, differential privacy, and practical hardenings, *IEEE Access* (2026).
- [30] M. I. U. Haq, S. Q. Paracha, S. D. Qamar, S. T. G. Naqvi, Federated learning-driven cyber-physical security framework for ai-powered smart grids in renewable-integrated urban infrastructures, in: 2025 5th International Conference on Digital Futures and Transformative Technologies (ICoDT2), IEEE, pp. 1–6.
- [31] J. Li, C. Zheng, Z. Chen, Resilient federated learning for vehicular networks: A digital twin and blockchain-empowered approach, *Future Internet* 17 (2025) 505.
- [32] V. Ramalingam, B. Kumar, S. K. Gupta, D. M. Alsekait, D. S. Abdelminaam, A hybrid federated learning framework with generative ai for privacy-preserving and sustainable security in iot-enabled smart environments, *Scientific Reports* 16 (2026) 3071.
- [33] S. Khaf, G. Kaddoum, Federated hierarchical reinforcement learning for resilient spectrum sharing in 6g non-terrestrial networks, *IEEE Open Journal of the Communications Society* (2026).
- [34] J. A. Isong, S. O. Ajakwe, D.-S. Kim, Xs-fedprs: Explainable and secure federated learning for privacy-preserving genomic analytics in federated healthcare networks, *IEEE Internet of Things Journal* (2026).
- [35] B. McMahan, E. Moore, D. Ramage, S. Hampson, B. A. y Arcas, Communication-efficient learning of deep networks from decentralized data, in: *Artificial intelligence and statistics*, Pmlr, pp. 1273–1282.
- [36] K. Bonawitz, V. Ivanov, B. Kreuter, A. Marcedone, H. B. McMahan, S. Patel, D. Ramage, A. Segal, K. Seth, Practical secure aggregation for privacy-preserving machine learning, in: *proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security*, pp. 1175–1191.
- [37] C. Dwork, A. Roth, The algorithmic foundations of differential privacy, *Foundations and trends® in theoretical computer science* 9 (2014) 211–487.
- [38] I. Mironov, Rényi differential privacy, in: 2017 IEEE 30th computer security foundations symposium (CSF), IEEE, pp. 263–275.
- [39] Y.-X. Wang, B. Balle, S. P. Kasiviswanathan, Subsampled rényi differential privacy and analytical moments accountant, in: *The 22nd international conference on artificial intelligence and statistics*, PMLR, pp. 1226–1235.
- [40] W. B. Johnson, J. Lindenstrauss, et al., Extensions of lipschitz mappings into a hilbert space, *Contemporary mathematics* 26 (1984) 1.

Author's Biography

Md Mazharul Islam received the B.Sc. and M.Sc. degrees in computer science and engineering from North South University, Dhaka, Bangladesh. He has served as a Research Assistant with the Institute for Advanced Research (IAR) Lab (United International University in collaboration with North South University) and with the Cyber-Physical System Research Lab at North South University. He received the North South University Vice-Chancellor's Gold Medal in 2024. His research interests include cyber-security, artificial intelligence, machine learning, searchable encryption, privacy-preserving systems, blockchain for healthcare, and cyber-physical systems. He has published papers in several prospective conferences and journals.

Mohammad Kaosain Akbar is currently a Ph.D. student in the Department of Computer Science at the University of Calgary, Canada. He received his M.A.Sc. in Systems Engineering from Concordia University, Canada, and his B.Sc. in Computer Science and Engineering from North South University, Bangladesh. His research interests include software engineering, applied machine learning, machine learning for security applications, time-series analysis, non-intrusive load monitoring, smart energy systems, and data-driven AI applications. He has authored and co-authored several peer-reviewed journal and conference papers in applied artificial intelligence, energy analytics, smart grid applications, and machine learning-based systems.

Niaz Ashraf Khan is a dedicated academic professional with over seven years of experience in Computer Science and Engineering. He is currently a Senior Lecturer in the Department of Computer Science and Engineering at BRAC University, Dhaka, Bangladesh. Niaz holds a Master's degree in Computer Science and Engineering from North South University, Dhaka, Bangladesh, where he also completed his Bachelor's degree. His research interests lie at the intersection of Sound Signal Processing, Natural Language Processing (NLP), Machine Learning, and Deep Learning.